COMPUTERS & SECURITY 73 (2018) 266–293

Available online at www.sciencedirect.com

ScienceDirect

journal homepage: www.elsevier.com/locate/cose

Computers & Security

Taxonomy of mobile users' security awareness

Ron Bitton, Andrey Finkelshtein, Lior Sidi, Rami Puzis, Lior Rokach, Asaf Shabtai *

Department of Software and Information Systems Engineering, Ben-Gurion University of the Negev, Beer-Sheva, 84105, Israel

ARTICLE INFO

Article history:
Received 16 December 2016
Received in revised form 25 July 2017
Accepted 30 October 2017
Available online 8 November 2017

Keywords:
Security awareness
Mobile devices
Taxonomy
Social engineering
Analytic hierarchy process

ABSTRACT

The popularity of smartphones, coupled with the amount of valuable and private information they hold, make them attractive to attackers interested in exploiting the devices to harvest sensitive information. Exploiting human vulnerabilities (i.e., social engineering) is an approach widely used to achieve this goal. Improving the security awareness of users is an effective method for mitigating social engineering attacks. However, while in the domain of personal computers (PCs) the security awareness of users is relatively high, previous studies have shown that for the mobile platform, the security awareness level is significantly lower. The skills required from a mobile user to interact safely with his/her smartphone are different from those that are required for safe and responsible PC use. Therefore, the awareness of mobile users to security risks is an important aspect of information security. An essential and challenging requirement of assessing security awareness is the definition of measureable criteria for a security aware user. In this paper, we present a hierarchical taxonomy for security awareness, specifically designed for mobile device users. The taxonomy defines a set of measurable criteria that are categorized according to different technological focus areas (e.g., applications and browsing) and within the context of psychological dimensions (e.g., knowledge, attitude, and behavior). We demonstrate the applicability of the proposed taxonomy by introducing an expert-based procedure for deriving mobile security awareness models for different attack classes (each class is an aggregation of social engineering attacks that exploit a similar set of human vulnerabilities). Each model reflects the contribution (weight) of each criterion to the mitigation of the corresponding attack class. Application of the proposed procedure, based on the input of 17 security experts, to derive mobile security awareness models of four different attack classes, confirms that the skills required from a smartphone user to mitigate an attack are different for different attack classes.

© 2017 Elsevier Ltd. All rights reserved.

1. Introduction

During the past decade, the adoption of smartphones has increased dramatically.[1] The popularity of smartphones, coupled with the amount of valuable and private information they hold, make them attractive to attackers. As a result, organizations and individuals have begun to realize the importance of securing their mobile phones, much like they would secure their personal computers (PCs) and servers.

* *Corresponding author.*
E-mail address: shabtaia@bgu.ac.il (A. Shabtai).
https://doi.org/10.1016/j.cose.2017.10.015
0167-4048/© 2017 Elsevier Ltd. All rights reserved.
[1] https://www.gsma.com/mobileeconomy/.

Information security awareness (ISA) is widely recognized as an important aspect of information security (Siponen, 2001). While ISA for PCs is relatively high, research has shown that for the mobile platform, the ISA level is significantly lower (Androulidakis and Kandus, 2011a). The skills required from a mobile user to interact safely with his/her smartphone are different from those that are required for safe and responsible PC use. Previous researches have studied the human aspects of information security in the mobile device context (Albrechtsen, 2007; Allam et al., 2014; Androulidakis and Kandus, 2011a; Esmaeili, 2014; Mylonas et al., 2013). However, there is no agreed upon method of measuring security awareness for the mobile platform – mobile security awareness (MSA). Furthermore, although a taxonomy of security awareness has been defined for the PC world, to the best of our knowledge, a comprehensive taxonomy of security awareness that is focused on the mobile platform has not yet been defined. Such a mobile security taxonomy is required for the development of a reliable method for measuring MSA.

The enormous amount of information stored on smartphones, together with the wide range of connectivity options available, has resulted in various types of attacks on smartphones, most of which involve vulnerabilities related to human factors. Different types of attacks may exploit different sets of human vulnerabilities. Therefore, the skills needed by a mobile user to detect or prevent one type of attack may not be the same needed in the face of another kind of attack. The majority of ISA approaches broadly address security awareness, without focusing on a specific type of threat or attack. We believe that the mobile domain requires a more precise definition of security awareness – one that considers ISA within the context of a specific attack. However, generating an awareness model for each attack is impractical. Thus, we group attacks into classes based on the human vulnerabilities that they exploit.

In this paper, we define the MSA of a person in terms of the specific skills (i.e., the knowledge, attitude, and behavior) required regarding specific mobile technologies to mitigate a particular class of attacks. Defining the MSA in this way and assessing it in relation to sets of skills required for mobile security awareness results in a more accurate assessment of the MSA with significant operational implications. By knowing the specific attack classes that a user is more vulnerable to, an organization can invest efforts and resources more efficiently to increase awareness and improve the security of its systems.

The taxonomy is based on Kruger and Kearney's prototype for assessing security awareness in organizations (Kruger and Kearney, 2006), which we have adapted for the mobile domain. To do so, we surveyed the domains of mobile security and security awareness and explored a variety of human vulnerabilities, along with taxonomies of mobile attacks and threats. The product is a comprehensive taxonomy that defines the criteria of a mobile security aware person. The criteria are categorized according to different technological focus areas (e.g., applications, and browsing) and within the context of psychological dimensions (e.g., knowledge, attitude, and behavior). The criteria are also measurable and can therefore be used to assess the security awareness of mobile users. In addition, we present an expert-based procedure that uses the analytical hierarchical process (AHP) in order to derive a separate MSA model for a specific attack class. We implemented this procedure, applying the AHP to data obtained from online questionnaires completed by 17 security experts. The results of this procedure revealed interesting information about the importance of the criteria and focus areas with regard to the attack classes, and these observations support our main hypothesis that mitigating different attacks requires different sets of capabilities. Consequently, the MSA should be estimated per attack class.

The rest of the paper is organized as follows: Section 2 provides relevant background, introducing the prototype that our work is based upon (Kruger and Kearney, 2006). Section 3 provides a detailed description of the components and structure of the suggested mobile security awareness taxonomy. In Section 4, we outline the process of evaluating the security awareness of mobile users regarding a specific class of attacks and propose an expert-based procedure for deriving a separate MSA model for a specific attack class. In section 5, we implement the proposed procedure, based on the input of security experts, in order to derive a security awareness model. This section also includes a description of the attack classes and a discussion about insights gained regarding the awareness models, attack classes, and taxonomy components. Section 6 contains a survey of related works on security awareness in different domains. In the last section, we conclude with the paper's contributions, discuss additional applications of the proposed method, and outline future work.

2. Background

The definition of measurable criteria for a security aware person is an essential and challenging aspect of assessing ISA. Kruger and Kearney's prototype is helpful in defining these criteria and suggests methods for measuring them in the context of ISA in organizations (Kruger and Kearney, 2006). In their work, Kruger and Kearney encourage organizations to define *focus areas* (i.e., primary issues related to the organization's ISA) and explore them in the following psychological dimensions: *knowledge*, *attitude*, and *behavior*. Each of the dimensions addresses a specific psychological aspect of the focus area and contains criteria (i.e., factors) that assist in the dimension's measurement. For instance, password strength is a primary focus area related to organizational ISA. Examining this focus area in the various psychological dimensions raises the following issues: (1) whether the employee knows what a strong password is (knowledge); (2) whether the employee perceives the use of strong passwords as useful in increasing the organization's information security (attitude); and (3) whether the employee uses strong passwords (behavior). Considering such issues makes it easier to formulate the criteria of a security aware person in this specific focus area. In this case, a person with a high level of ISA knows what a strong password is, perceives the use of strong passwords as useful, and uses strong passwords. While the first two criteria are easily measured using surveys or questionnaires, the latter is more challenging in that a person, particularly an employee, is not always willing to reveal his/her true behavior to others. Therefore, in order to measure criteria related to the behavioral dimension, Kruger and Kearney suggest using a physical test to verify the declared behavior.

After defining and measuring the criteria, they recommend assisting security experts in the task of estimating the contribution of each criterion to the overall awareness score. Because of the hierarchical structure of their methodology and the difficulty of ranking multiple criteria simultaneously, Kruger and Kearney advise applying the analytic hierarchy process (AHP) (Saaty, 1988) in which experts rank pairs of criteria in the same focus area, as well as focus area pairs themselves. The primary benefits of this process are: (1) ranking pairs is more accurate than ranking multiple items simultaneously, and (2) ranking between nodes with the same parent in the hierarchy reduces the time complexity of the entire process.

Our proposed MSA taxonomy is based on Kruger and Kearney's prototype. In accordance with the prototype, we formulated the criteria by defining focus areas and exploring them in the context of three psychological dimensions (i.e., knowledge, behavior, and attitude). However, while Kruger and Kearney's focus areas target the primary issues related to the organization's ISA, we redefined and adjusted these focus areas for the mobile domain. In addition, unlike, Kruger and Kearney's prototype, which assesses a general awareness model, our method provides a separate MSA model for each class of attacks, resulting in a model which generates a score that is more accurate given the diverse nature of attacks on the mobile platform and the human vulnerabilities exploited by the attacks.

3. The mobile security awareness taxonomy

The mobile security awareness taxonomy consists of several building blocks and their relationships, as presented using a class diagram in Fig. 1. The main building blocks of the taxonomy are the focus areas and psychological dimensions. The focus areas (e.g., "Applications") are high-level categories that are relevant to information security in the mobile platform. A focus area consists of sub-focus areas, which are technological aspects related to smartphones; for example, "Application Installation" is one of the sub-focus areas of the "Applications" focus area. Each sub-focus area includes several security topics that encompass a specific information security concern associated with the sub-focus area. For example, "Untrusted Sources" is a security topic associated with the "Application Installation" sub-focus area, which refers to the installation of applications from untrusted sources.

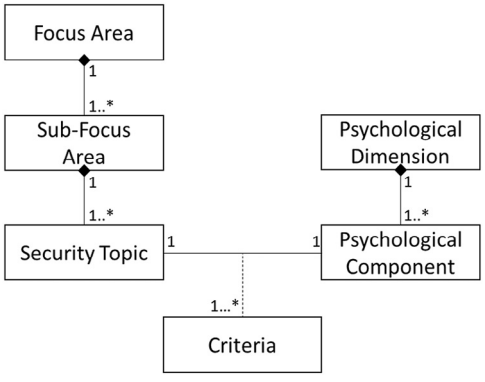


Fig. 1 – A class diagram of the main building blocks of the proposed taxonomy.

We used the three psychological dimensions (knowledge, attitude and behavior) developed and implemented in previous research to evaluate information security awareness (Kruger and Kearney, 2006), in order to enrich the technological security aspects (sub-focus areas) with users' psychological traits. In order to formulate a more concrete definition of a person's attitude, knowledge, and behavior with regard to a security topic, we address several psychological components for each dimension, as done in prior research (Androulidakis and Kandus, 2011a; Esmaeili, 2014; Mylonas et al., 2013; Someswar Kesh, 2007). By further extending the definition of the psychological dimensions in this way (i.e., with psychological components), we were able to obtain a more detailed description of the psychological traits concerning mobile security. For instance, we found "Confronting Behavior" (i.e., actions that the user performs when confronting a security risk) to be a crucial psychological component in defining behavior with regard to information security.

The leaves of the taxonomy are the measurable criteria for a mobile security aware person, which are positioned at the intersection of a security topic and a psychological component. For example, "Unknown Sender" is a security topic associated with the "Virtual Communication" sub-focus area. By considering this topic along with the "Confronting Behavior" psychological component, we formulated the criterion: "Does not open emails/messages received from unknown senders".

It should be noted that the focus areas, sub-focus areas, and security topics might change over time due to new technologies, features, and threats that are introduced to the mobile domain. Therefore, the proposed taxonomy, and more specifically the criteria, must be reviewed and updated regularly in order to reflect these changes and maintain an up-to-date taxonomy.

3.1. *The focus areas, sub-focus areas, and security topics of mobile security*

The focus areas are located at the highest level of the proposed taxonomy for the mobile security domain. In order to obtain a comprehensive understanding of information security in smartphones, we reviewed actual attack case studies related to mobile platforms, third party attack databases, and security related topics in the news. Based on these information sources and prior research on security awareness, we derived four main focus areas that encompass information security awareness in smartphones: "Applications," "Communication and browsing," "Channels," and "Device." In order to create a robust and stable taxonomy, the focus areas were derived in a manner that is unrelated to a specific attack or technology. Each focus area was divided into several sub-focus areas and security topics. This enables the taxonomy to include the full range of technological aspects associated with mobile security awareness. In the sub-sections that follow, we explain the reasons for including these focus and sub-focus areas and discuss relevant security topics. The hierarchical structure of subjects associated with mobile security awareness

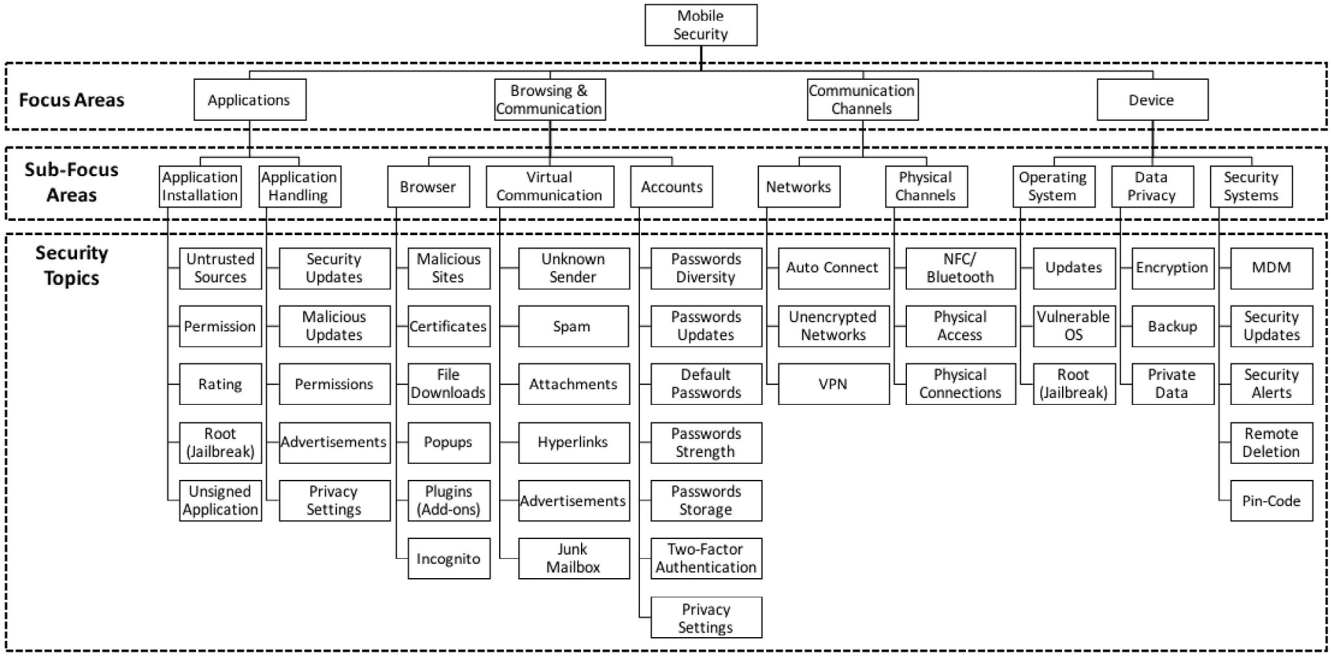


Fig. 2 – The hierarchical structure of technological elements associated with mobile security awareness.

comprising focus areas, sub-focus areas, and security topics included in our proposed taxonomy is presented in Fig. 2.

3.1.1. *Applications*

According to He et al. (2015), the amount of malware in mobile devices has increased by more than 600% since 2012, with over 250,000 malware in the Android operating system alone. Official application stores, such as Google Play and Apple's App Store, scan the applications they offer for traces of known malware and remove the applications if such traces are detected. Nevertheless, malicious applications can occasionally be found on the websites of these two major application hubs. Malicious applications are often spread by third party application stores, forums, and emails. Benign applications can also be a significant privacy threat that users are rarely aware of (Zhou and Jiang, 2012; Zhu et al., 2014).

The application sandboxing model and access control mechanisms used in most of today's smartphone operating systems cannot fully protect the device from threats caused by applications. An access control mechanism in which the user grants permissions to an application (such as the permission mechanism in the Android OS and iOS) can easily be hacked through social engineering, or because of users' lack of interest or limited understanding (Haris et al., 2014; Kelley et al., 2012; Mylonas et al., 2014; Vidas et al., 2011). Moreover, the careless behavior of users with rooted or jailbroken devices may permit applications to bypass the application sandboxing mechanism (Damopoulos et al., 2011; Peng et al., 2014). Given these threats, smartphone applications are a crucial factor in security awareness. We address two main issues regarding applications (i.e., sub-focus areas): "Application installation" and "Application handling".

3.1.1.1. *Application installation*. The source of an application (e.g., Google Play, Apple's App Store) is an important indicator in the assessment of ISA, as applications from dubious sources are more likely to be malicious (Felt et al., 2011; Mylonas et al., 2013; Zhou and Jiang, 2012). Applications uploaded to official markets must be signed by their authors. A user with a high level of MSA is more likely to verify that signature (Vidas et al., 2011). Due to the fact that repackaging (i.e., adding additional functionality to an application) is one of the most common techniques used by malware authors (Zhou and Jiang, 2012), the rating and number of downloads are parameters that can assist the user in understanding the danger level before installing a new application. In addition, the permission set requested when installing a new application is extremely critical (Mylonas et al., 2014; Vidas et al., 2011). Consequently, in most versions of the Android operating system, the permissions of an application are only granted at installation time. Thus, the user must understand the risk that the application can pose to the device and data before installation (Miller, 2011; Vidas et al., 2011).

3.1.1.2. *Application handling*. The security concerns of mobile users do not end once an application has been installed. The user is asked to make decisions regarding security and privacy issues while handling the application, including decisions pertaining to permission granting, privacy settings, access control, and application updating, and making such decisions wisely requires a high level of information security awareness. For instance, Android's latest version and iOS allow the user to manage (at run-time) the permissions that were provided to installed apps. In addition, the latest version of Android forces third party applications to request sensitive permissions at runtime. Furthermore, applications tend to update often, and each update can change the application or its permissions. Applications may request new permissions from the user during an update, but the reason for granting these permissions is not always clear. On the one hand, application updates are needed

for resolving software vulnerabilities and fixing bugs (Paganini, 2014). On the other hand, attack case studies have shown that applications can change their form and become malicious after being updated (J. L. (Communications), 2013; Tenenboim-Chekina et al., 2013; Zhou and Jiang, 2012). On a rooted device, applications may also ask the user to grant them super-user access at run-time, an action that breaks the sandbox model and can be used as an attack vector (Damopoulos et al., 2011; Peng et al., 2014). Besides the permissions that are granted by the user at run-time and/or at the time of installation, many applications contain their own privacy settings, and configuring these settings carefully requires a high security awareness level.

3.1.2. *Browsing and communication*

Smartphone mobile devices have dramatically changed the ways we communicate with each other, consume data, and browse the web (Karikoski and Soikkeli, 2013). In terms of information security, social and technological flaws that exist in mobile phones expose smartphone users to threats such as spam, phishing, account hijacking, and malicious QR barcodes. According to Virvilis et al. (2014), mastering security in this domain will help the user identify and mitigate such attacks. In this focus area, we address the following main issues (sub-focus areas): "Browser," "Virtual communication," and "Accounts."

3.1.2.1. *Browser*. Browsing on mobile devices presents threats similar to those encountered by browsing on a personal computer; for example, storing malicious code in websites (Park et al., 2014) which may facilitate a derive-by download attack (Zhou and Jiang, 2012). Therefore, similar principles of safe behavior may be applied, for example, avoiding malicious sites, blocking pop-ups and spam, validating site certificates, and avoiding giving personal details to untrusted web services. The sensitive information stored on smartphones (e.g., contact lists, call logs, SMSs, pictures, and videos), and the fact that smartphones accompany users to any place and at all times, also exposes the user to a new set of threats. For instance, a web application can gain access to embedded sensors on the mobile device, including the camera, GPS, accelerometer, gyroscope, and microphone. Another example are malware exploiting the mobile browser to gain system-level privileges (Damopoulos et al., 2011; Greenberg, 2013).

3.1.2.2. *Virtual communication*. In addition to traditional mobile communication platforms (e.g., phone calls, SMSs and MMSs), new communication platforms have been developed specifically for mobile phones (e.g., WhatsApp, Tinder), and others from the PC world have been adjusted for use in the mobile domain (e.g., Facebook, LinkedIn, Twitter, Skype, and email clients). User communication is a well-known attack vector, misused by attackers to perform social engineering to hijack the user's device or account (Peng et al., 2014).

3.1.2.3. *Accounts*. Virtual communication usually has built-in account settings including passwords and security setting. These settings are accessible through the mobile device. Hackers may hijack an account (Oliver, 2014; Thomas, 2014) and harm the user by revealing private data such as photos and credit card details (Rainie, 2013), or by accessing valuable data within business correspondence. When an account has been hijacked, it is extremely difficult to restore it, and most users give up their account. Using strong passwords, selecting different passwords for different services, updating passwords regularly, and storing passwords appropriately are actions that prevent most hijacking attacks (Androulidakis and Kandus, 2011a; Stanton et al., 2005).

3.1.3. *Communication channels*

Smartphone users must be aware of information security while using its communication channels, as many attempts to exploit their security vulnerabilities have already occurred. This focus area differs from the "Communication and browsing" focus area described above which focuses on the activity conducted on these channels. Smartphones have many connectivity capabilities, and cellular networks, Wi-Fi, Bluetooth, and USB are some examples of the communication and information sharing channels used. Many of the channels support multiple protocols. These protocols have different properties, features, and implementations; while some protocols take into account the security issue, other protocols have limited or no security or privacy features. In order to take a closer look at these communication channels, we have divided this focus area into the following sub-focus areas: "Networks" and "Physical channels."

3.1.3.1. *Networks*. Almost every mobile device is connected to cellular networks and 3/4G Internet. In addition, Wi-Fi hotspots, providing Internet services to mobile devices, have become popular and routinely used by smartphone users. Gadgets such as hands-free devices and selfie sticks use Bluetooth in order to connect to smartphones. These, and other channels, can pose a threat to the smartphone. The Bluetooth protocol has already been used as an attack vector (Androulidakis and Kandus, 2011b; Hypponen, 2006; La Polla et al., 2013; Peng et al., 2014). Untrusted Wi-Fi networks are fertile ground for network attacks such as eavesdropping, SSL strip, and man-in-the-middle (MiTM) attacks (Beekman and Thompson, 2013; Damopoulos et al., 2011; Danchev, 2013; La Polla et al., 2013; Park et al., 2014), and even mobile networks are not always safe and can be exposed to risks (Lackey and Miras, 2009). VPNs (virtual private networks), security tools, and settings can help the user minimize the risk that exists when connecting to different networks (Park et al., 2014). Moreover, the ability to identify security issues can help the user prevent network attacks like the SSL strip attack.

3.1.3.2. *Physical channels*. Aside from networks, mobile devices can also be physically connected to other devices and components. Memory cards, personal computers, headphones, charging stations, and other gadgets, devices, and accessories form the long and growing list of physical channels. In this sub-focus area we have also included entities (other than the user of the device) that can reach the device physically. Physical channels are not immune to attacks. The examples range from "simple" attacks, such as stealing the device in order to access information on the device or install malware (Hypponen, 2006), as well as more sophisticated attacks where memory cards and USB connections to computers have been used to cause an infection on a device (Felt et al., 2011; Peng et al., 2014).

Other examples of physical channels exploited by malicious entities are recovery partition (i.e., recovery mode) (Vidas et al., 2011), malicious chargers (Lau et al., 2013), protection cases (Gluck et al., 2017), and replacement screens (Shwartz et al., 2017). The users' security awareness of physical channels and the danger that exists in connecting to untrusted components can protect them from exposing their device to "physical" attacks.

3.1.4. *Device*

The device and the way it is configured and protected constitutes an important focus area. The use of security services that are built-in or installed on top of the operating system can often help prevent attacks on smartphones. The sub-focus areas that we consider in the "Device" focus area are "Operating system," "Data," and "Security systems."

3.1.4.1. *Operating system*. Vulnerabilities in an operating system can cause great damage to the device and the information on it, and expose the device to a wide range of other attacks (Damopoulos et al., 2011; Danchev, 2013; Forristal, 2014; J. L. (Communications), 2013; Messmer, 2013; Prabhu, 2014; Saran, 2014; Tung, 2014). In addition, operating systems offer built-in security features, and therefore, an up-to-date operating system is very important. "Rooting" or "jailbreaking" the device can be a double-edged sword. It can grant the user more power over the device (e.g., by updating to an unsupported, unofficial, and newer OS version), so the user can perform advanced actions that may better protect the device (e.g., installing an intrusion detecting system). At the same time, super-user access can be used by malicious entities to escalate their privileges and cause damage (Miller, 2011; Park et al., 2014; Vidas et al., 2011). Unofficial OS versions cannot always be trusted as they may have a "backdoor" or built-in malware installed. Users should think twice before "rooting" or "jailbreaking."

3.1.4.2. *Data privacy*. Smartphones store a vast amount of personal data (Mylonas et al., 2014), thus making the devices the target of many malicious entities. Access control mechanisms (such as the permission mechanism) assist the user in protecting his/her data privacy. In addition, screen locking, the use of account passwords, and encryption are some of the ways a user can protect the data on the device (Androulidakis and Kandus, 2011c; Park et al., 2014).

3.1.4.3. *Security systems*. The importance of security systems for personal computers is quite common; however, users have not yet realized the value of smartphone security systems. In Androulidakis and Kandus (2011a), researchers asked students in Budapest whether they use antivirus on smartphones. Only 30% of the students knew for certain that their devices were protected with antivirus, and less than 13% actually used it. In addition to antiviruses, many other helpful security systems exist. Security features and settings offered by the operating system (e.g., VPN services, PIN-code, and encryption), along with third party security applications, (e.g., mobile device management, and remote wipe services) can help users prevent, remove, and disinfect malware and other attacks on their devices.

3.2. *Dimensions*

To enrich technological security aspects (sub-focus areas) with users' psychological traits, we follow Kruger and Kearney's prototype (Kruger and Kearney, 2006) by considering each aspect in light of three psychological dimensions (i.e., attitude, knowledge, and behavior). This was also pointed out in Boyatzis and Kolb (1991) and Carlton et al. (2015); both studies stated that the definition of skills should include the knowledge, experience, and ability to do something well. This technique has already proven to be effective for assessing information security awareness (Thompson and Von Solms, 1998). In their prototype, Kruger and Kearney provide a single definition for each dimension as follows: what does a person know with regard to a security topic (knowledge); how does a person feel about a security topic (attitude); and how does a person act (behavior). Based on recent publications (Androulidakis and Kandus, 2011a; Esmaeili, 2014; Mylonas et al., 2013; Someswar Kesh, 2007), we further extend the definition of the psychological dimensions with psychological components, as presented in Fig. 3.

3.2.1. *Attitude*

A subject's attitude toward security has been investigated by a variety of security researchers and psychologists. Kruger and Kearney (2006) defined attitude as how a person feels about a security topic. Ng and Rahim (2005) defined attitude as the user's tendency to respond positively to computer security practices. Esmaeli suggested a model for assessing factors that affected information security behavior in smartphones (Esmaeili, 2014). He developed and demonstrated a model based on the decomposed theory of planned behavior, where security behavior is derived and affected by many factors, including security attitude. In the proposed taxonomy, we use Esmaeli's definition of security attitude concerning mobile security and use the following psychological components to define attitude in the context of mobile security:

1. **Perceived probability of a threat** – the user believes that the probability of security breaches on his/her smartphone is high.
2. **Perceived severity of a threat** – the user believes that security breaches could risk his/her resources.
3. **Perceived usefulness of recommended behavior** – the user believes that security practice behaviors on his/her smartphone can be effective.

For example, a user with a high level of mobile security awareness is a person who perceives that malware infection is a common threat among users; a person who perceives malware infection as a risk to his/her phone or privacy; and/or a person who perceives that using an updated antivirus is an effective action to defend his/her smartphone.

3.2.2. *Knowledge*

Knowledge about threats, along with becoming familiar with methods to detect and prevent them, is a key factor in a user's

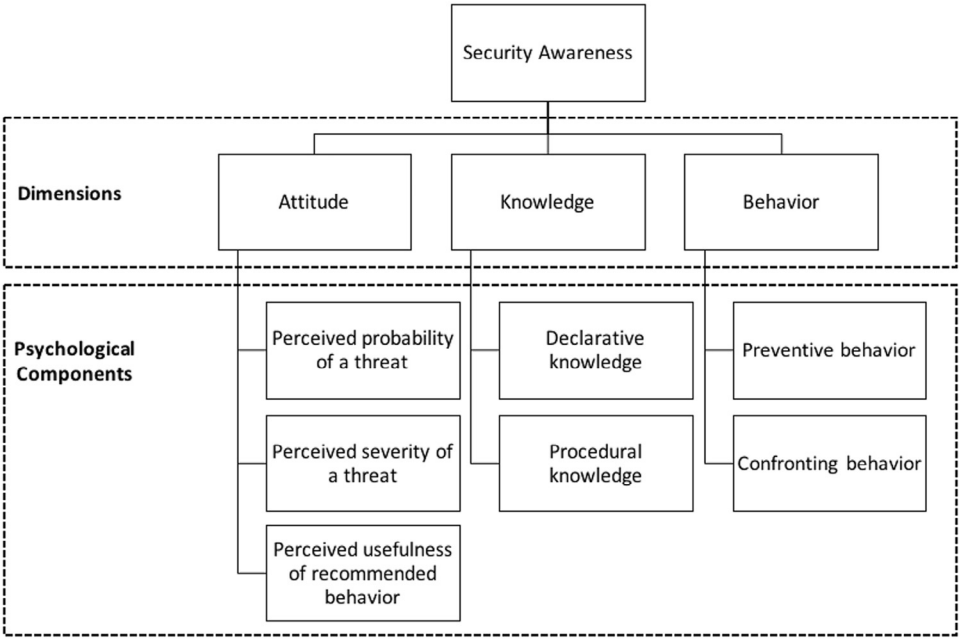


Fig. 3 – A hierarchical structure of the psychological dimensions and components.

ability to protect against attacks on his/her mobile phone. The importance of knowledge has been addressed through security awareness programs. Albrechtsen (2007) pointed to the improvement of employees' security awareness by addressing tactical knowledge through group-based discussion. Asanka and Love (2014) showed that procedural ("know how") and conceptual knowledge ("know that") positively affect self-efficacy, which enhances computer users' phishing threat avoidance. Kruger and Kearney (2006) defined knowledge simply as what a person knows.

In the mobile platform, Mylonas et al. (2013) successfully showed that non-security savvy users are less aware of the mobile threats than security savvy users. Esmaeili (2014) proved that security knowledge and experience from the PC platform lead to more secure behavior in the mobile platform.

In our taxonomy, we use Kesh and Ratnasingam's (2007) approach in which they developed an information-security knowledge architecture (ISKA). Using the ISKA, the authors explored the knowledge dimension within the context of information technology (IT). In accordance with their paper, we use the following two psychological components for defining knowledge with regard to mobile security:

1. **Declarative** – the user knows about the existence of a threat and is familiar with the existence of an appropriate countermeasure (security-control).
2. **Procedural** – the user knows how to operate the security-control.

For example, a knowledgeable user in mobile security is a person who knows that antiviruses exist (declarative) and knows how to use them for scanning a device for malware (procedural). These two components are general enough to cover the knowledge dimension and they are also easy to collect and evaluate.

3.2.3. *Behavior*

Kruger and Kearney (2006) defined behavior based on a person's actions in different focus areas. A report from 2011 shows that 79.8% of mobile phone infections were the result of content downloaded from malicious websites or delivered by Bluetooth and SMS messages. This finding supports the fact that the behavior is an indicator of the person's ISA or MSA level.

Prior research has discussed aspects of behavior in the context of information security awareness in smartphones. Some studies focused on a single facet of smartphone security, while others touched upon several aspects. Previous work helps us to understand how to consider smartphone users' behavior, obtain a better look at facets of smartphone security, and measure behavior. In most papers related to measuring secure behavior, the authors try to understand *how a person acts* with their smartphone in everyday situations. Another approach for measuring users' behavior with respect to information security is to look at *how a person acts* within a context or in a particular situation, for example, when a user receives an unsolicited email with a password reset request.

From the work conducted on mobile security awareness assessment (Androulidakis and Kandus, 2011a; Esmaeili, 2014; Mylonas et al., 2013) we identify the following two psychological components for defining behavior with regard to mobile security:

1. **Preventive behavior** – actions that the user performs to reduce the risk of being exposed to an attack.
2. **Confronting behavior** – actions that the user performs while facing a security risk.

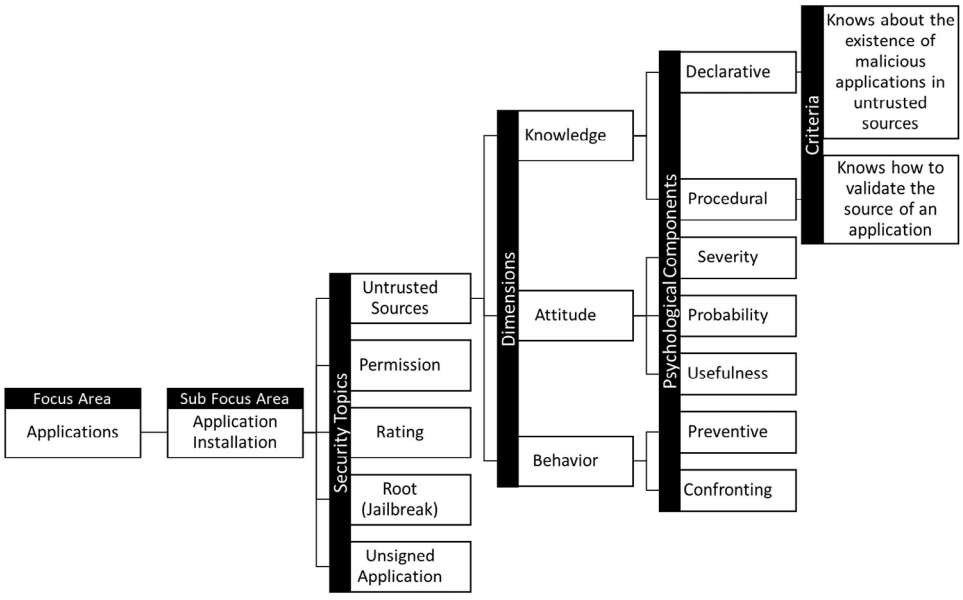


Fig. 4 – An example of one path in the MSA taxonomy tree which involves the "Untrusted Sources" security topic and the psychological components that are associated with the knowledge dimension (i.e., declarative knowledge and procedural knowledge).

For instance, installing and updating antivirus software on the device are preventive behaviors, and ignoring/deleting a phishing email are confronting behaviors. We find that these behavior types address the most important assessment criteria in user behavior regarding mobile devices.

3.3. *The criteria for a mobile security aware person*

The criteria for a mobile security aware person are the leaves of the taxonomy tree. They are derived by exploring each security topic within the context of a specific psychological component (i.e., the intersection of the mobile security hierarchy and the security awareness (dimensions) hierarchy. For example, "Untrusted Sources" is a security topic associated with the "Application installation" sub-focus area). As can be seen in Fig. 4, by combining the "Untrusted Sources" security topic with the psychological components that are associated with the knowledge dimension, we can formulate the following criteria: (1) the user knows about the existence of malicious applications in untrusted sources (declarative knowledge); and (2) the user knows how to validate application sources (procedural knowledge). We formulated more than 150 criteria for a mobile security aware person. The complete list of criteria is provided in Appendix A.

4. Proposed process for computing the MSA score of a person to a specific attack class

In this section, we utilize the proposed taxonomy and present an expert-based procedure (security expert) for deriving MSA models for a specific attack class. An attack class is defined as a group of social engineering attacks that exploit a similar set of human vulnerabilities. Each MSA model reflects the contribution (weight) of each criterion to the mitigation of the corresponding attack class. In this section, we also present an application of the awareness model in which we describe how the awareness models can be used for computing the MSA score of a user for a specific class of attacks.

4.1. *Deriving awareness models for attack classes*

The task of ranking multiple criteria simultaneously is extremely difficult for an individual to accomplish, often resulting in an inaccurate ranking. Moreover, a synchronous pairwise comparison between pairs of criteria is not feasible for a large amount of criteria. The analytic hierarchy process (AHP) (Saaty, 1988) is designed to moderate these drawbacks. The AHP represents the problem space as a hierarchical structure in which the experts only compare pairs of elements at the same level of the hierarchy, thus reducing the amount of comparison needed to a more reasonable amount resulting in a more precise ranking.

In our case, the default implementation of the AHP would require the experts to compare pairs of elements for both the sub-focus area and security topic levels, which would result in 190 comparisons (145 for the security topic level and 45 for the sub-focus area level). Although, this is lower than the number of all pairwise comparisons required in a naïve approach (1431 comparisons), it still requires a significant amount of expert time. Therefore, in order to further reduce the number of comparisons, in the proposed process the expert first ranks the criteria in each sub-focus area separately. Then, we apply the AHP on the sub-focus area level. In this manner, the number of comparisons required is at worst approximately 99 (ranking 54 criteria and comparing all pairs in the 10 sub-focus areas).

The process of assessing the importance of the criteria for each class of attacks using the AHP consists of the following phases:

Table 1 – Interpretation of experts ranking.

Interpretation	Value of $M^k_{i,j}(a)$	Value of $M^k_{j,i}(a)$
i is significantly more relevant to the attack class than j	3	$\frac{1}{3}$
i is more relevant to the attack class than j	2	$\frac{1}{2}$
i and j are equally relevant to the attack class	1	1
j is more relevant to the attack class than i	$\frac{1}{2}$	2
j is significantly more relevant to the attack class than i	$\frac{1}{3}$	3

Phase I: **Ranking the criteria in each sub-focus area.** Our assumption is that the contribution of each criterion to mitigate the different attack classes may not be the same. Therefore, in this phase the expert ranks the relevant criteria in each of the sub-focus areas by assigning a rank between 0 to 2 (0 - not relevant, 1 - slightly relevant, and 2 - highly relevant). The final rank of each criterion is normalized by the sum of the ranks of all of the criteria associated with the same sub-focus area. We denote the normalized rank assigned by expert k for criterion i associated with sub-focus area j for attack class a as $normRank^k_{i,j}(a)$.

Phase II: **Ranking sub-focus areas**. The expert ranks pairs of sub-focus areas. During this phase, each sub-focus area is presented, along with all of the criteria considered by the expert as relevant in the previous phase (ranked as 1 or 2). Given two sub-focus areas i and j, the expert ranks them to one of the following levels:

(1) i and j are equally relevant to the attack class
(2) i is more relevant to the attack class than j
(3) i is significantly more relevant to the attack class than j

Phase III: **Applying the AHP process for computing the weights of sub-focus areas**. In this phase, we follow the AHP process in order to derive the weights for the sub-focus areas. First, we create a matrix (denoted as M) containing all pairwise comparisons of the sub-focus areas, where the cell $M^k_{i,j}(a)$ represents expert k's comparison of sub-focus areas i and j regarding the attack class a (during phase II). The value of $M^k_{i,j}(a)$ is defined in accordance with the first axiom of the AHP in which given two AHP criteria i and j and an expert ranking n, if i is n times more relevant than j then j is $\frac{1}{n}$ time less relevant than i as presented in Table 1.

Next, we calculate the geometric mean of each row in M. The use of geometric mean is based to the definition of the AHP process, which ensures the first axiom of the AHP still holds after the geometric mean aggregation. Finally, we calculate the weight for sub-focus area j as follows (where n is the number of sub-focus areas):

$$sfa^k_j(a) = \frac{GeometricMean\,(row_j)}{\sum_{i=1}^{n} GeometricMean\,(row_i)} \quad (1)$$

Phase IV: **Computing the contribution of each criterion**. The contribution of criterion i associated with sub-focus area j computed for expert k for attack class a is derived as follows:

$$w^k_{i,j}(a) = normRank^k_{i,j}(a) \cdot sfa^k_j(a) \quad (2)$$

Phase V: **Integrating experts' criteria ranking.** The final rank for a specific criterion and attack class is derived by averaging the ranks computed by all experts as follows, $w_{i,j}(a) = \frac{1}{n}\sum_k w^k_{i,j}(a)$ where n is the number of experts that provided the ranking for attack class a. $w_{i,j}(a)$ represents the awareness model of attack class a.

4.2. *Computing the MSA score of a user for an attack class using the awareness models*

In this section, we describe how the awareness models can be used for computing the MSA score of a user u and a specific attack class a. This process is presented in Fig. 5. As can be seen, there are two inputs to the MSA score computation process: (1) the MSA model, which is represented by a set of weights $w_{i,j}(a)$ assigned for each criterion i in sub-focus area j and attack class a; and (2) the set of measured values for each

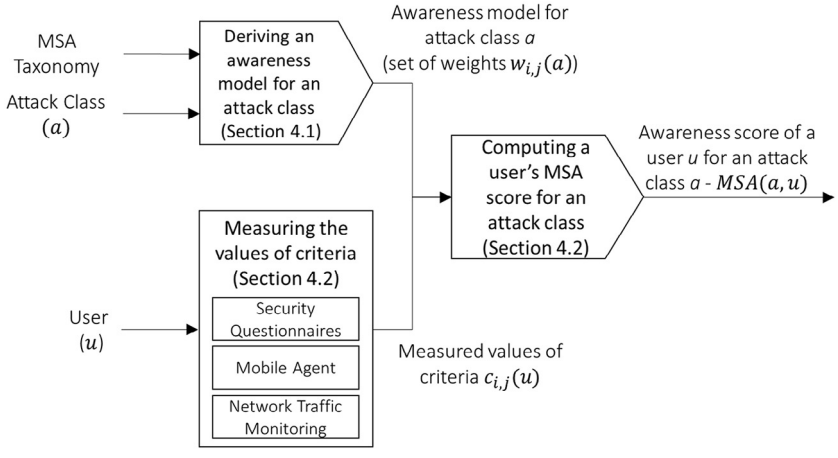


Fig. 5 – The process of computing the MSA of a user for an attack class.

criterion $c_{i,j}(u)$ for user u. There are several methods that can be used for measuring the values of criteria for a certain user. Interviews and multiple choice questions are common methods that have already proven to be effective for measuring criteria associated with the knowledge and attitude dimensions (Kruger et al., 2006) (for example, criterion AI1 in Appendix A "Knows about the existence of malicious applications in untrusted sources and familiar with the existence of trusted sources"). Criteria associated with the behavioral dimension can be extracted by observing the user's actual behavior using an agent installed on his/her mobile phone or by monitoring his/her network traffic. For example, the criterion "Does not open emails/messages received from unknown senders" (criterion VC2 in Appendix A) can be measured by observing (using the mobile agent) the number of spam emails read by the user. Although this approach is usually reliable and accurate, it raises issues of privacy and intrusiveness, especially when monitoring employees in a working environment. Nevertheless, despite their intrusiveness, various security countermeasures (such as mobile device management applications, email inspection, deep packet inspection, intrusion detection systems, and agent-based security solutions) are already being used by most organizations today. We believe that in order to measure the criteria presented in our taxonomy, the information provided by these countermeasures can be utilized. Another approach of measuring the criteria associated with the behavioral dimension is based on interviews or questionnaires (i.e., measuring self-reported behavior). This approach, however, is limited, because users are not always aware of their actual behavior.

After deriving the awareness models and measuring the criteria for a certain user, the MSA score of user u for attack class a is calculated as the weighted sum of the measured values for criteria:

$$MSA(a,u) = \sum_{j} \sum_{i \in j} w_{i,j}(a) \cdot c_{i,j}(u) \quad (3)$$

where $c_{i,j}(u)$ is the value derived for user u for criterion $c_{i,j}$ and $w_{i,j}(a)$ is the contribution of criterion $c_{i,j}$ in mitigating attack class a.

5. Applying the procedure of deriving awareness models for attack classes

In this section, we apply and demonstrate the procedure for deriving an awareness model of an attack class (presented in section 4.1). For the demonstration, we first define four classes of mobile attacks. Then, we enlisted the assistance of 17 security experts in order to assess the importance of each criterion to the various attack classes (i.e., deriving the awareness models). Finally, we analyze the awareness models generated and share insights which may be important for security awareness studies in the future.

5.1. *Defining the classes of mobile attacks*

In order to better understand smartphone attacks that exploit the human vulnerability, we surveyed several taxonomies of mobile attacks and threats. Foozy et al. (2011) suggested looking at information security in the areas of technical hacking and social engineering (they categorize social engineering as technical-based and human-based). The approach of Krombholz et al. (2014) to social engineering involved looking at the operator (human, software), channel (email, social networks, etc.), and type (social, physical, etc.) of the attack. Based on these taxonomies, and together with the attack case studies discussed in section 3.1, we define the following classes of attacks:

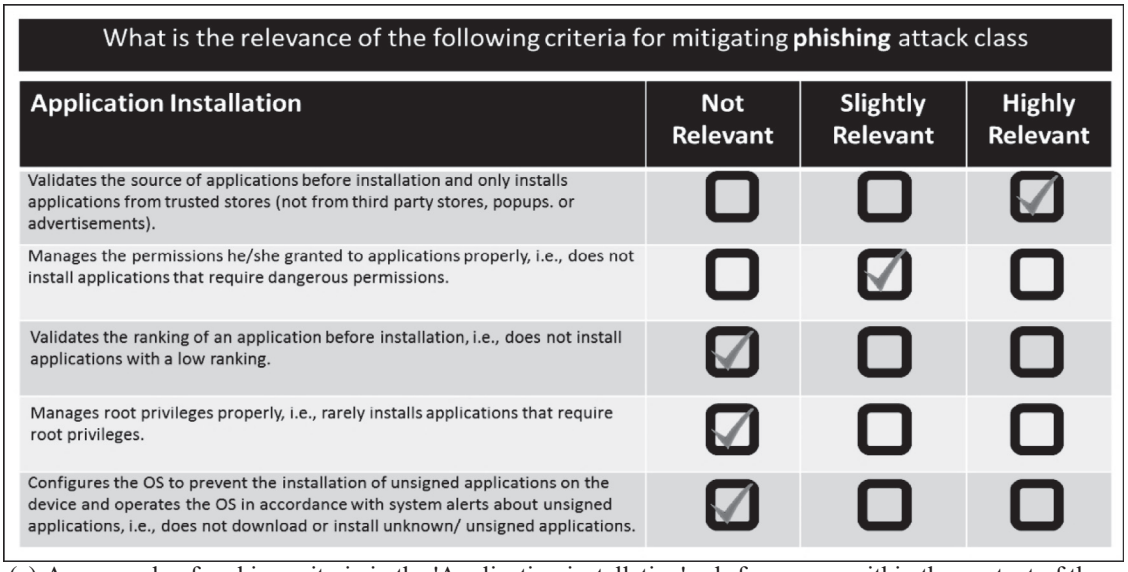
1. **Man-in-the-middle attacks (MiTM)** – Session/signal hijacking, SSL strip, eavesdropping, and rouge access point.
2. **Phishing attacks** – Emails, websites, URL, SMS, IM, IRC, forums, and social network frauds (e.g., fake links, friends/game requests).
3. **Application attacks** – Notifications (e.g., error messages), in-app pop-ups, malicious advertisements, clicking frauds, Trojans applications, and rootkits.
4. **Weak authentication attacks** – Password cracking, password reuse, default passwords, and no screen lock.

These classes encompass most of the common attacks on smartphones. It is important to note they are only examples, and their definition and inclusion in this research is not an attempt to map or fully cover the smartphone attack world.

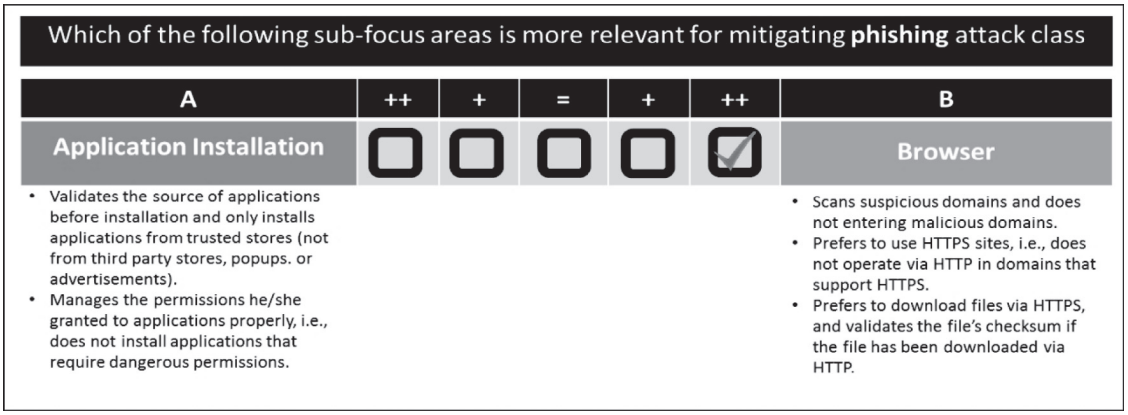
5.2. *Application of the procedure*

The procedure for ranking criteria (i.e., phases I and II of the proposed process for deriving an awareness model for an attack class) was implemented as an online questionnaire (web application) deployed with Amazon Web Services (AWS). Using this questionnaire, security experts and researchers can easily contribute to this research by defining new attack classes, formulating new criteria, and ranking criteria based on its importance for attack classes. Fig. 6 provides an example of the implemented questionnaire. Fig. 6(a) illustrates phase I of the process in which the user ranks the relevant criteria in each of the sub-focus areas by assigning a rank between 0 and 2, in this case ranking criteria in the "Application installation" sub-focus area within the context of the phishing attack class. Fig. 6(b) illustrates phase II of the procedure in which the expert ranks sub-focus areas by comparing pairs of sub-focus areas, in this case comparing the importance of the "Application installation" and "Browser" sub-focus areas for mitigating phishing attacks.Seventeen security experts selected from both academia and industry ranked the criteria using the online questionnaire; each expert performed the procedure on several classes of attacks in his/her area of expertise. In order to obtain optimal results in generating the awareness models, each expert was asked to provide the ranking for (one or more) attack classes within their area of expertise. In Fig. 7, we present descriptive statistics for the experts (their age and years of experience, in which a year of experience is defined as practical experience in the specific domain of the selected class of attacks).

Tables 2 and 3 respectively present the average sub-focus areas' weight functions and the average focus areas' weight functions regarding the attack classes. The average sub-focus areas' weight function for an attack class is derived by



(a) An example of ranking criteria in the 'Application installation' sub-focus area within the context of the phishing attack class.

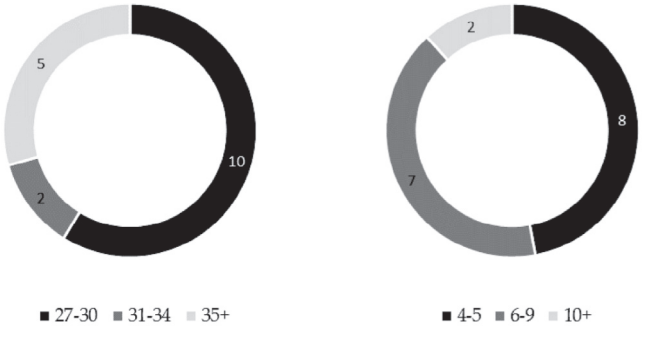


(b) An example of ranking sub-focus areas – comparing the importance of 'Application installation' and 'Browser' sub-focus areas for mitigating phishing attacks.

Fig. 6 – An example of the implemented online security expert questionnaire.

accumulating the ranks computed by all of the experts as follows, $sfa_j(a) = \sum_{i \in j} w_{i,j}(a)$. Similarly, the average focus areas' weight function for an attack class is computed by accumulating the weights of sub-focus areas (i.e., $sfa_j(a)$) associated with the specific focus area. The weight reflects the importance of the security awareness criteria in the specified sub-focus area for the different attack classes.

In order to validate that the experts agree upon the importance of criteria to mitigate different classes of attacks, we calculated the cosine similarity between each pair of experts ranking the same attack class. Table 4 presents the average cosine similarity of experts regarding an attack class. As can be seen, the results range from 0.85 to 0.92, indicating that the experts agree on the importance of the sub-focus areas to the attack classes and prove that the assessment we present is acceptable by security experts.



(a) Age

(b) Year of experience

Fig. 7 – Descriptive statistics for the experts.

6. Discussion

Based on the results of the AHP process, we make the following interesting observations about the importance of the focus areas and criteria with regard to the attack classes.

Table 2 – Sub-focus areas' weight functions for attack classes.

	Application Installation	Application Handling	Browser	Account	Virtual Communication	Operating System	Data Privacy	Security Systems	Network	Physical Channels
Application	0.262	0.088	0.159	0.007	0.234	0.061	0.004	0.112	0.044	0.031
MiTM	0.051	0.034	0.399	0.028	0.130	0.063	0.004	0.091	0.181	0.021
Phishing	0.050	0.048	0.250	0.175	0.395	0.006	0.003	0.024	0.050	0.000
Weak authentication	0.057	0.038	0.169	0.392	0.100	0.019	0.060	0.064	0.063	0.038

6.1. *Observation 1: Browsing and communication are key factors in assessing MSA*

As presented in Table 3, the "Browsing and communication" focus area was assigned the highest weight in all of the attack classes. We attribute this to the fact that most of today's attacks depend on the Internet as the attack vector. In contrast, the "Communication channels" focus area, which mainly relies on physical proximity (access) to the target, was assigned with a low weight in three out of the four attack classes.

In addition, as presented in Table 2, the "Browser" and "Virtual communication" sub-focus areas associated with the "Browser and communication" focus area were assigned high weights in three out of four attack classes (i.e., Application, MiTM, and Phishing). Moreover, the "Accounts" sub-focus area, which is also associated with the "Browser" and "Virtual communication" sub-focus areas, was assigned the highest weight in the weak authentication attack class.

6.2. *Observation 2: Proper handling and management of applications is essential in assessing MSA*

Following "Browsing and communication," the "Applications" focus area was found to be important for assessing the security awareness of mobile users in the application attack class (see Table 3). Application installation and handling (i.e., source of the application, permissions, and updates) is also a known attack vector used to lure users into installing malicious software.

6.3. *Observation 3: The criteria of some sub-focus areas contributed differently to different attack classes*

By observing the importance (weight) of the sub-focus areas (see Table 2), we noticed the strong contribution of the "Browser" sub-focus area in three out of four attack classes. What we found more interesting is the diversity in the importance of the criteria associated with the "Browser" sub-focus area among the different classes of attacks. In Fig. 8 we compare (using radar charts), the importance of criteria for selected attack classes in different sub-focus areas. Each radar chart refers to a specific sub-focus area (e.g., chart (a) refers to the "Browser" sub-focus area), and each variable in the chart indicates the importance of a criterion (on a scale of 0 to 1) for attack classes having similar weight for the sub-focus area. The criteria are represented by their index in Appendix A. As shown in Fig. 8(a), the B2, B6, B8, and B9 criteria, which are associated with the "Browser" sub-focus area and reflect the user's awareness regarding the management of certificates (i.e., installation, deletion, and validation), were found to contribute greatly to contribute greatly to the MiTM attack class. Another interesting observation is that most of the criteria (i.e., B1, B2, B4, B7 and B9) make a similar (medium) contribution to the Phishing attack class.

This can be also seen in the "Virtual communication" sub-focus area (Fig. 8(b)), when comparing the Application and Phishing attack classes, as well as in the "Application installation" and "Security systems" sub-focus areas (Figs. 8(c) and 8(d)), when comparing the Application and Week Authentication

Table 3 – Focus areas' weight functions for attack classes.

	Applications	Browsing and Communication	Communication Channels	Device
Application	0.35	0.4	0.075	0.177
MiTM	0.085	0.557	0.202	0.158
Phishing	0.098	0.82	0.05	0.033
Weak authentication	0.095	0.661	0.101	0.143

Table 4 – Average cosine similarity among the experts for each attack class.

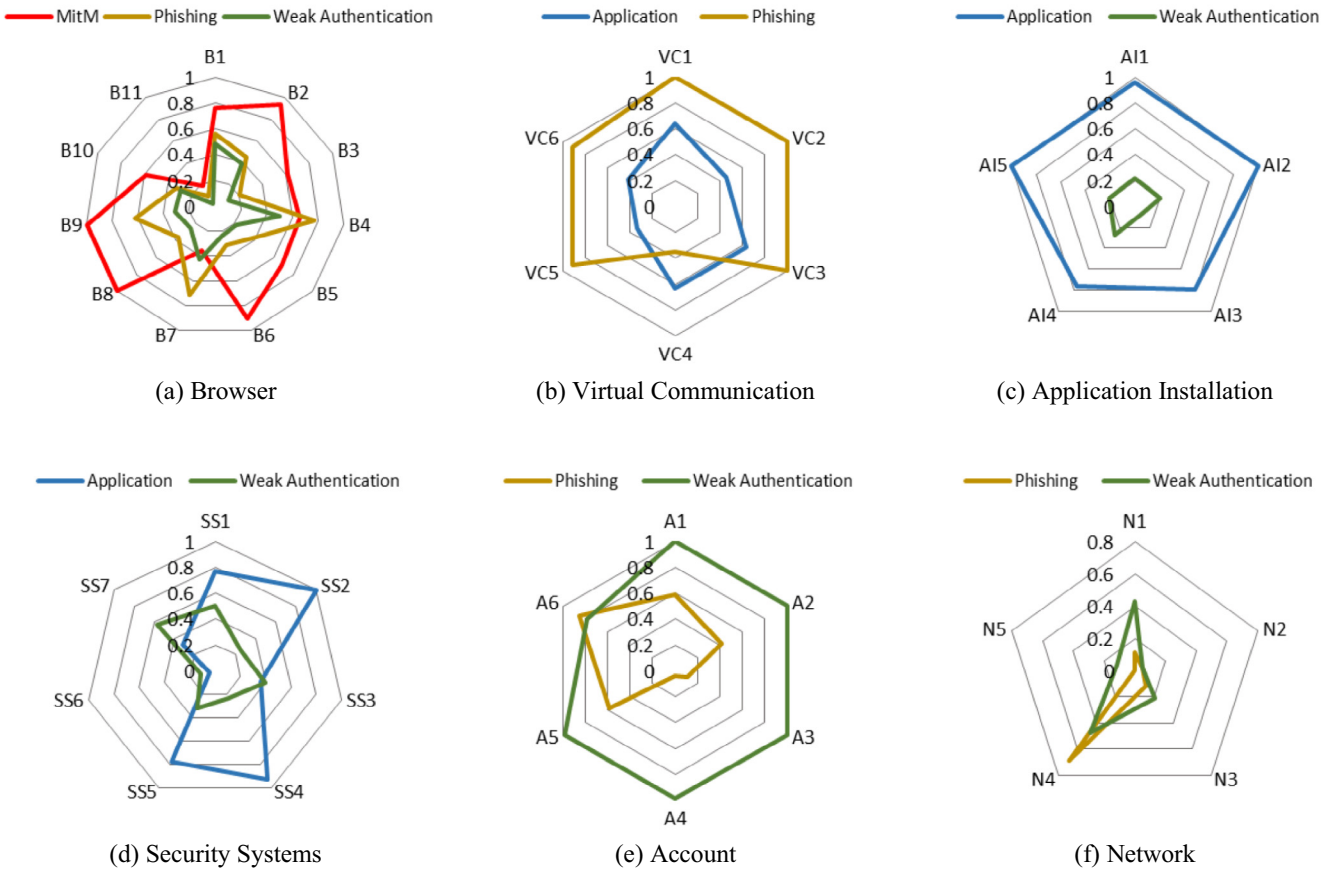
	Average Cosine Similarity	Number of Experts
Application	0.88	10
Man-in-the-Middle Attack	0.85	11
Phishing	0.92	10
Weak Authentication	0.87	13

attack classes, and the "Account" and "Network" sub-focus areas (Figs. 8(e) and 8(f)), when comparing the Phishing and weak authentication attack classes.

Two important insights can be derived from the above observations. First, analysis of the factors that affect different attack classes should consider the importance of sub-focus areas and also be more granular by evaluating the criteria as well (especially in sub-focus areas which received similar scores for different attacks). Second, the observations support our hypothesis that the mobile security awareness should be estimated per attack class, because as the results show, mitigating different attacks requires different sets of skills (i.e., knowledge, attitude, and behavior) from the smartphone user.

7. Related works

Various attempts to measure the security awareness of users have been made. In this section, we describe existing methods for assessing the ISA of PC users, as well as techniques and models that focus on mobile technologies. A summary of relevant papers in the domain of security awareness (both PC and mobile platforms) is presented in Table 6.



(a) Browser (b) Virtual Communication (c) Application Installation

(d) Security Systems (e) Account (f) Network

Fig. 8 – The significance of the criteria of the same sub-focus area for different attack classes.

Table 6 – Methods for security awareness of mobile users.

Paper	Domain	Dimensions			Sub-Focus Areas										Type of Awareness Model	Comments
		Knowledge	Attitude	Behavior	Application Installation	Application Handling	Browser	Account	Virtual Communication	Operating System	Data Privacy	Security Systems	Network	Physical Channels		
(Siponen, 2001)	General security awareness	Yes	Yes	Yes	No	No	No	No	No	No	No	No	No	No	General awareness model	A general definition of several dimensions of security awareness with no practical assessment of awareness.
(Kruger et al., 2006)	Organization (PC)	Yes	Yes	Yes	No	No	Yes	Yes	Yes	No	No	Yes	No	Yes	ISA model (Does not address the mobile domain)	A framework for assessing ICT security awareness.
(Stanton et al., 2005)	Organization (PC)	No	No	Yes	No	No	No	Yes	Yes	No	Yes	No	No	No	No awareness model	A taxonomy of end user behaviors.
(Androulidakis and Kandus, 2011a, 2011b, 2011c)	Mobile	Yes	Yes	Yes	Yes	No	No	Yes	Yes	Yes	Yes	Yes	Yes	Yes	General MSA model	Does not cover important aspects of smartphone security awareness.
(Esmaeili, 2014)	Mobile	Yes	Yes	Yes	Yes	No	No	No	No	No	Yes	Yes	No	Yes	General MSA model	Does not cover important aspects of smartphone security awareness.
(Mylonas et al., 2013)	Mobile	Yes	Yes	Yes	Yes	Yes	No	No	No	Yes	Yes	Yes	No	Yes	General MSA model	Does not cover important aspects of smartphone security awareness.
(Pittayachawan and Dang-Pham, 2014)	Mobile	No	Yes	Yes	No	No	Yes	No	Yes	No	No	No	No	Yes	General MSA model	Assesses how attitudes affect behavior in different contexts. Does not cover important aspects of smartphone security awareness.

7.1. General methods for assessing security awareness

The idea of viewing security awareness in different contexts is not new. Siponen claimed that security awareness should be considered based on two different characteristics – descriptive and prescriptive (Siponen, 2001). The descriptive characteristic represents the user's knowledge regarding security, in contrast to the prescriptive characteristic, which is defined in the paper as "the action-guiding commitment to the objectives of awareness by the user," i.e., his/her attitude and behavior. Later, Siponen claimed that security awareness should be discussed differently in different dimensions. The five dimensions he suggested considering are the organizational, general public, socio-political, computer ethical, and institutional education dimensions. Although, the author outlined each dimension, a comprehensive description of the factors in each dimension (i.e., technology or security topic) was not provided.

Kruger et al. proposed a framework based on Kruger and Kearney's prototype (Kruger and Kearney, 2006) to evaluate the security awareness of information and communication technology (ICT) in organizations (Kruger et al., 2006). They measured employees' knowledge, behavior, and attitude in focus areas generated using a value focused approach (VFA) which is a decision technique used to determine the stakeholders' wishes and concerns regarding ICT security. This study provides a thorough overview of organizational security awareness; however, it mainly focuses on PCs and does not address the mobile security domain.

The authors Stanton et al. (2005) suggested a taxonomy of end user security related behaviors in organizations. Although the taxonomy presented in this paper outlines an extensive list of behaviors, none of them address mobile technologies. In addition, their taxonomy focused on categorizing the behaviors on a two-dimensional scale: (1) attitude – the employee's intentions while performing the behavior (malicious, natural, and beneficial), and (2) knowledge – the level of expertise needed to perform the behavior (i.e., high and low). We found this mapping too generic. In the proposed taxonomy, the knowledge and attitude dimensions are extensively explored and are an essential component of each security topic.

7.2. Security awareness of mobile users

Androulidakis and Kandus investigated the security awareness of smartphone users through questionnaires (Androulidakis and Kandus, 2011a, 2011b, 2011c). They asked several closed questions to learn about mobile users' behavior, knowledge, and attitudes. The questions asked were about communication, Bluetooth settings and usage, the existence of an antivirus application, data storage, backup and encryption, protection of the SIM card and the device with passwords, content downloading, and physical access. Their method contributed significantly to our proposed taxonomy by pointing security topics that are relevant to smartphone technologies. However, their method does not cover important aspects of smartphone security awareness (such as application installation, application usage, browsing, and account security). In addition, for some aspects, they only asked questions within a single dimension. For example, for the aspect of communication they asked about the feeling (attitude), and for the antivirus aspect they asked about its presence (behavior). Furthermore, their method provides a general awareness score that is less accurate when addressing different attack classes.

Based on Androulidakis and Kandus' questionnaire, Esmaeli suggested a model for assessing factors that affected information security behavior in smartphone networks (Esmaeili, 2014). He developed and demonstrated a model based on the decomposed theory of planned behavior (DTPB), where security behavior is derived and affected by many factors, including security attitude. Esmaeli's method contributed significantly to our proposed taxonomy by pointing security attitude concerning mobile security. However, similar to Androulidakis and Kandus his method does not cover important aspect of smartphone security awareness and provide a general awareness model that is less accurate when addressing different attack classes.

In Mylonas et al. (2013) the authors explored the security awareness of smartphone users in the context of official application repositories (e.g., Google Play, and Apple's App Store). They attempted to answer three main questions: (1) Do users enable security controls; (2) Do users consider security when downloading applications; and (3) Do users trust the official application stores. To do so, they conducted a survey consisting of multiple questions centered on the following topics: application installation, security mechanisms, physical protection, and data protection. In addition, they presented a logistic regression model to predict the user's trust level regarding the official app repository. The conclusions reached were that most smartphone users trust official application markets, do not adopt security mechanisms, and do not consider security when installing applications. While their method contributed to the proposed taxonomy by pointing security topics that are relevant to smartphone technologies, their method does not cover important aspects of smartphone security awareness. In addition, the model presented in the paper was not targeted at assessing a user's ISA.

Pittayachawan and Dang-Pham attempted to understand the factors that affect the intention to behave safely with mobile devices across different contexts (Pittayachawan and Dang-Pham, 2014). In their study, they tried to answer two main questions: (1) Does the user's intention to perform malware avoidance behavior change across contexts, and (2) What are the contributing factors and their impacts on the user's intention to perform malware avoidance behavior. Using questionnaires, the authors investigated the influence of several factors in different contexts (home and university). The conclusion reached was that some of the factors that affect people's intention to perform malware avoidance behavior are different in different contexts.

8. Conclusions and future work

We present a taxonomy for mobile users' security awareness, developed utilization of an expert-based process for deriving a set of awareness models, each of which relates to a specific attack class. These models can then be used to assess the security awareness of smartphone users. We applied the proposed process for deriving the awareness models using security experts and analyzed the resulting models. The analysis

of the resulting models shows that the skills (i.e., knowledge, attitude, and behavior) required from a smartphone user to mitigate an attack vary based on the attack class. This supports our hypothesis that the mobile security awareness should be assessed per attack class. The high level of agreement between experts indicates that the taxonomy and the resulting models are sound, valid, and accepted by the experts.

The proposed method is robust to changes and can be adapted with a reasonable amount of effort when required. For instance, calculating the MSA score of users for a new attack class does not require reevaluating the criteria of the users. This is because the two inputs to the MSA score computation process (the MSA model, which is represented by a set of weights $w_{i,j}(a)$ assigned for each criterion i in sub-focus area j and attack class a; and the set of measured values for each criterion $c_{i,j}(u)$ for user u) are independent. Therefore, assuming that the set of measured values for the criteria for a user is provided, in order to compute the MSA for a new attack class (i.e., an attack class that is not one of the four attacks described in this paper) we only need to implement the procedure for deriving the awareness for the new attack class. In addition, the users' awareness can be periodically reassessed in order to evaluate the improvement of users with regard to an attack class or to measure the effectiveness of security awareness activities (e.g., security workshops).

By knowing the specific attack classes that a user is more vulnerable to, organizations can invest efforts and resources more efficiently to increase awareness and improve the security of its systems. For example, an organization can: conduct security awareness workshops dealing with specific types of attack classes or workshops for employees with a specific level of technology expertise; force vulnerable employees to install special certificates on their devices to better protect organizational services (e.g., complete interception of encrypted data); or prevent access of vulnerable employees to critical systems.

In addition to organizations, vendors (such as Internet service providers, OS developers, and smartphone manufacturers) can also benefit from the proposed method. With knowledge regarding the specific attack classes that most users are vulnerable to, vendors could identify dangerous trends, and update security countermeasures accordingly. For instance, OS developers can harden critical services for unaware users (e.g., to prevent unaware users from granting critical permissions to third party applications, or prevent unaware users from installing self-signed certificates). Internet service providers (ISPs) may provide increased forms of protection against account hijacking (such as preventing unaware users from entering unrated sites).

In future work we plan to integrate the taxonomy, expert-based procedure, and security awareness models in a framework for assessing the security awareness of smartphone users. The framework will collect data from the smartphones of real users using multiple data sources, such as a dedicated mobile agent, online security questionnaires, and a VPN that monitors the user's network traffic. The framework will use the information collected from these data sources to measure the relevant criteria described in this paper in order to compute the awareness scores. Using such a framework will enable us to answer various interesting research questions such as which sources of information (questionnaires, mobile agent, or network traffic) should be used for measuring each criterion.

Appendix A. – List of criteria

Topic	ID	Knowledge	Attitude	Behavior
Focus area: Applications	Sub-focus area: Application Installation (AI)			
Untrusted sources	AI1	*Declarative*: Knows about the existence of malicious applications in untrusted sources. *Procedural*: Knows how to validate the source of an application.	*Severity:* Perceives installing an application from an untrusted source as dangerous. *Probability:* Perceives the existence of malicious applications in untrusted sources as plausible. *Usefulness:* Perceives validating the source of applications as useful in protecting the device.	*Preventive:* Validates the source of applications before installation. *Confronting:* Installs applications solely from trusted sources.
Permissions	AI2	*Declarative:* Knows about the existence of applications that access sensitive data/services and familiar with the existence of access control mechanism on smartphones. (i.e., permission mechanism). *Procedural:* Knows how to use the permission mechanism (disable/enable a permission).	*Severity:* Perceives installing applications with dangerous permissions as behavior that could harm the device. *Probability:* Perceives the existence of applications that access sensitive information in (trusted/untrusted) app stores as plausible. *Usefulness:* Perceives proper management of the permissions granted to applications as useful in protecting the device.	*Preventive:* Does not install applications that require dangerous permissions. *Confronting:* Manages the permissions granted to applications properly.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Rating	AI3	*Declarative:* Knows about the existence of malicious applications in official stores and familiar with the rating mechanism for applications. *Procedural:* Knows how to validate the rating of an application.	*Severity:* Perceives installing applications with low ratings as dangerous. *Probability:* Perceives the existence of malicious applications in official stores as plausible. *Usefulness:* Perceives validating the rating of applications and installing highly rated applications as useful in protecting the device.	*Preventive:* Validates the rating of an application. *Confronting:* Does not install applications with a low rating.
Root/jailbreak	AI4	*Declarative:* Knows that malware uses super-user privileges to access sensitive components of the device and familiar with applications for managing root privileges. *Procedural:* Knows how to manage root privileges.	*Severity:* Perceives granting root privileges to a malicious entity as extremely dangerous. *Probability:* Perceives the existence of malicious applications that use root privileges to accesses sensitive components as plausible. *Usefulness:* Perceives proper management of root privileges as useful in protecting the device.	*Preventive:* Rarely installs applications that require root privileges. *Confronting:* Manages root privileges properly.
Unknown/unsigned applications	AI5	*Declarative:* Knows about the existence of malicious applications in unofficial stores and familiar with the existence of a signing mechanism for applications. *Procedural:* Knows how to configure the OS to prevent the installation of unsigned applications on the device.	*Severity:* Perceives installing unknown/unsigned applications as very dangerous. *Probability:* Perceives the existence of unsigned malicious applications in unofficial stores as plausible. *Usefulness:* Perceives proper configuration of the OS and operation of the OS in accordance with system alerts as valuable.	*Preventive:* Configures the OS to prevent the installation of unsigned applications on the device and does not download or install unknown/ unsigned applications. *Confronting:* Operates the OS in accordance with system alerts.
Focus area: Applications	Sub-focus area: Application Handling (AH)			
Security updates	AH1	*Declarative:* Knows that attackers may utilize known vulnerabilities to execute a threat against users with outdated applications and familiar with the fact that most updates are aimed at solving security breaches. *Procedural:* Knows how to update applications and configure update settings.	*Severity:* Perceives that using an outdated version of an application is dangerous. *Probability:* Perceives the existence of a known vulnerability of an outdated version of an application as plausible. *Usefulness:* Perceives properly updating applications as helpful in protecting his/her device.	*Preventive:* Configures the OS to update applications automatically. *Confronting:* Does not postpone security updates.
Malicious updates	AH2	*Declarative*: Knows that an application update may change the application's functionality and add additional sensitive permissions. *Procedural:* Knows how to configure update's settings to prevent applications that require additional permissions from being updated automatically.	*Severity:* Perceives that some updates may potentially ham his/her device. *Probability:* Perceives malicious updates as something that is likely to occur. *Usefulness:* Perceives managing updates properly, together with removing irrelevant/unused/ dangerous applications, as useful in protecting the device.	*Preventive:* Does not allow automatic updates of untrusted applications. *Confronting:* Does not perform updates that require sensitive permissions and removes irrelevant/unused/dangerous applications from the device.
Permissions	AH3	*Declarative:* Knows that malicious applications may utilize the permission mechanism for receiving access to sensitive resources and familiar with mechanisms that allow the user to manage the permissions at both installation time and run-time. *Procedural:* Knows how to manage application permissions.	*Severity:* Perceives that granting sensitive permissions to an application as dangerous. *Probability:* Perceives the existence of applications that ask for sensitive permissions (both in official and unofficial stores) as plausible. *Usefulness:* Perceives restricting an application's access to sensitive data and sensors as helpful in protecting the device.	*Preventive:* Does not install applications that require sensitive permissions. *Confronting:* Manages application permissions properly and restricts applications' access to sensitive and unrelated resources.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Application advertisements	AH4	*Declarative:* Knows that malicious advertisements may redirect the user to a malicious website, and that advertisements are not always related to the application that publishes them andfamiliar with services used to validate suspicious domains. *Procedural:* Knows how to validate the domain of a website.	*Severity:* Perceives inserting private information into advertiser's websites as dangerous. *Probability:* Perceives the existence of malicious advertisements as plausible. *Usefulness:* Perceives inserting private information into an advertiser's site as behavior that may jeopardize privacy and that validating the domain of a website helps avoid this privacy risk.	*Preventive:* Rarely clicks on advertisements. *Confronting:* Does not insert private information into advertiser's websites before validating it.
Privacy settings	AH5	*Declarative:* Knows that malicious entities may leverage publicly available information of the user to execute a threat and familiar with the fact that most applications contain their own privacy settings. *Procedural:* Knows how to configure privacy settings inside applications.	*Severity:* Understands that using unsecure privacy settings for applications may put his/her privacy at risk. *Probability:* Perceives the existence of malicious entities that leverage publicly available information of the user as plausible. *Usefulness:* Realizes that properly setting applications' privacy settings will help protect the user's privacy.	*Preventive:* Properly configures applications' privacy settings to preserve privacy. *Confronting:* Operates in accordance with security alerts.
Focus area: Browsing and Communications Sub-focus area: Browser (B)				
Malicious sites	B1	*Declarative:* Knows about the existence of phishing and malicious domains and familiar with security mechanisms used to validate domains and URLs. *Procedural:* Knows how to scan domains and URLs.	*Severity:* Perceives entering a malicious domain as dangerous. *Probability:* Perceives the existence of a malicious domain as plausible. *Usefulness:* Perceives validating suspicious domains and URLs as useful in protecting the device and the user's privacy.	*Preventive:* Validates suspicious domains and does not enter malicious domains. *Confronting:* Operates in accordance with security alerts.
Certificates -General	B2	*Declarative:* Knows about the existence of phishing and malicious domains and familiar with security mechanisms used to validate domains. *Procedural:* Knows how to operate via HTTPS.	*Severity:* Perceives entering a malicious domain as dangerous *Probability:* Perceives the existence of a malicious domain as plausible. *Usefulness:* Perceives the use of HTTPS as useful for preserving his/her privacy.	*Preventive:* Prefers to use HTTPS sites. *Confronting:* Does not operate via HTTP in domains that support HTTPS.
Certificates - File downloads	B3	*Declarative:* Knows that malicious entities may replace/change files downloaded via HTTP and familiar with security mechanisms used to avoid this threat (certificate mechanism) and the use of validating the signature of applications (e.g., SHA Checksum). *Procedural:* Knows how to validate a domain certificate and checksum of a file.	*Severity:* Perceives downloading files using HTTP as dangerous *Probability:* Perceives the existence of malicious entities that replace/change files downloaded via HTTP as plausible. *Usefulness:* Perceives downloading files via HTTPS and validating the checksum of files as useful in protecting the device.	*Preventive:* Prefers to download files via HTTPS. *Confronting:* Validates the file's checksum if the file has been downloaded via HTTP.
Certificates - Data confidentiality	B4	*Declarative:* Knows about the existence of malicious entities that may intercept the users' Internet traffic and familiar with the difference between HTTP and HTTPS. *Procedural:* Knows how to distinguish between HTTP and HTTPS and how to switch to HTTPS.	*Severity:* Perceives that operating via HTTP threatens privacy. *Probability:* Perceives the existence of malicious entities that intercept Internet traffic as plausible. *Usefulness:* Perceives the use of HTTPS as useful for preserving his/her privacy.	*Preventive:* Prefers to use HTTPS sites. *Confronting:* Does not send sensitive information via HTTP.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Pop-up blockers	B5	*Declarative:* Knows that malicious entities may utilize the pop-up mechanism to execute a threat and familiar with the existence of pop-up blockers. *Procedural:* Knows how to block pop-ups.	*Severity:* Perceives inserting private information into pop-ups as behavior that may lead to information disclosure. *Probability:* Perceives the existence of malicious pop-ups as plausible. *Usefulness:* Perceives the use of pop-up blockers as useful in protecting the device.	*Preventive:* Uses pop-up blockers. *Confronting:* Does not insert private information into pop-ups.
Certificates - Deletion	B6	*Declarative:* Knows that attackers can lure the user to install malicious certificates and familiar with browser and system alerts related to certificates. Familiar with alerts related to certificates (e.g., self-signed, expired etc.). *Procedural:* Knows how to manage the device's certificates, i.e., delete unknown certificates.	*Severity:* Perceives the existence of unknown/untrusted certificates on the device as dangerous (i.e., perceives operating with untrusted certificates as dangerous). *Probability:* Understands that certificate attacks are likely to occur. *Usefulness:* Perceives deleting unknown/untrusted certificates from the device and operating with trusted certificates as useful for protecting privacy.	*Preventive:* Deletes unknown certificates from the device. *Confronting:* Operates in accordance with system/browser alerts and does not use untrusted certificates.
Advertisements/ advertising sites	B7	*Declarative:* Knows that malicious entities may utilize the advertisement mechanism to execute a threat and familiar with the existence of advertisement blockers. *Procedural:* Knows how to use/ install advertisement blockers.	*Severity:* Perceives inserting personal information into advertisers' sites as behavior that may jeopardize the user' s privacy *Probability:* Perceives the existence of malicious advertisements as plausible. *Usefulness:* Perceives using advertisement blockers as useful in protecting his/her privacy.	*Preventive:* Uses advertisement blockers. *Confronting:* Does not insert private information on advertisers' sites.
Certificates installation	B8	*Declarative:* Knows that attackers can lead the user to install malicious certificates and familiar with browser and system alerts related to certificates. Familiar with alerts related to certificates (e.g., self-signed, expired etc.). *Procedural:* Knows how to manage the device's certificates, i.e., delete unknown certificates.	*Severity:* Perceives the existence of unknown/untrusted certificates on the device as dangerous (i.e., perceives the danger in installing a new certificate.). *Probability:* Understands that certificate attacks are likely to occur. *Usefulness:* Perceives that preventing the installation of unknown/untrusted certificates as useful for protecting his/her privacy.	*Preventive:* Carefully manages the certificates on the device. *Confronting:* Operates in accordance with system/browser alerts and does not install untrusted certificates.
Certificates - Validation	B9	Declarative: Knows that attackers can lead the user to operate with untrusted certificates (e.g., self-signed, expired etc.) and familiar with browser and system alerts related to certificates Procedural: Knows how to validate suspicious certificate.	*Severity:* Perceives operating with unknown/untrusted certificates as dangerous. *Probability:* Understands that certificate attacks are likely to occur. *Usefulness:* Perceives validating a domain's certificate and operating in accordance with system alerts regarding certificates as useful in protecting privacy.	*Preventive:* Does not operate with untrusted certificates. *Confronting:* Validates domain certificates and operates in accordance with system/browser alerts.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Plugins, add-ons, extensions	B10	*Declarative:* Knows that attackers can utilize browser plugins (i.e., extensions/add-ons) to perform different attacks and familiar with mechanisms to validate the source of plugins/add-ons. *Procedural:* Knows how to validate the source of plugin/add-on and erase unwanted plugins.	*Severity:* Perceives installing malicious plugins as dangerous. *Probability:* Understands that malicious plugins are likely to occur in official and unofficial stores. *Usefulness:* Perceives validating the source of a plugin and only installing signed plugins as useful in protecting his/her device.	*Preventive:* Properly manages the plugins/add-ons/extensions installed on his/her browser and erases unwanted plugins. *Confronting:* Validates the signature and source of a plugin before installation.
Private browsing	B11	*Declarative:* Knows that while using the browser additional data (e.g., history, cookies and authentication credentials) is stored on the device, and familiar with private browsing. *Procedural:* Knows how to switch to private browsing.	*Severity:* Perceives revealing session cookies and authentication credentials to malicious entities as dangerous. *Probability:* Understands that user's data stored on shared devices (e.g., an Internet coffee shop) can be transmitted to malicious entities. *Usefulness:* Understands that using private browsing could be helpful in protecting the user's privacy.	*Preventive:* Rarely inserts private data on a device that is not owned by the user (or on a shared device). *Confronting:* Uses incognito mode (i.e., private browsing) while using a device that is not owned by the user (or a shared device).
Focus area: Browsing and Communications Sub-focus area: Virtual Communication (VC)				
Malicious hyperlinks	VC1	*Declarative:* Knows that attackers send malicious emails (e.g., spam emails, phishing emails) to users in order to execute a threat (e.g., baiting the user to click a malicious hyperlink). *Procedural:* Knows how to identify suspicious hyperlink.	*Severity* Perceives clicking on a hyperlink received from an unknown sender (or from a spammer) as dangerous. *Probability:* Perceives malicious emails (spam emails) containing malicious hyperlinks as something that is likely to occur. *Usefulness:* Perceives that avoiding clicking suspicious hyperlinks as useful in protecting his/her privacy.	*Confronting:* Does not click on suspicious hyperlinks.
Unknown sender (spammer)	VC2	*Declarative:* Knows that attackers send malicious emails (e.g., spam emails, phishing emails) to users in order to execute a threat (e.g., phishing attacks) and familiar with mechanisms used to validate the sender of an email and domains. *Procedural:* Knows how to identify the source of an email and domains.	*Severity*: Perceives opening emails/ messages received from an unknown sender or from a spammer as dangerous. *Probability:* Perceives malicious emails (spam emails) as something that is likely to occur. *Usefulness:* Perceives validating the sender of emails as useful in protecting his/her privacy	*Preventive:* Validates the sender of an email. *Confronting:* Does not open emails/ messages received from unknown senders (or spam).
Unknown sender/ spam - hyperlinks	VC3	*Declarative:* Knows that attackers send emails that contain malicious hyperlinks and familiar with mechanisms used to validate hyperlinks (i.e., URL). *Procedural:* Knows how to validate hyperlinks embedded in suspicious emails.	*Severity* Perceives clicking on a hyperlink received from an unknown sender (or from a spammer) as dangerous. *Probability:* Perceives malicious emails (spam emails) containing malicious hyperlink as something that is likely to occur. *Usefulness:* Perceives validating URLs embedded in suspicious emails as useful in protecting his/ her privacy.	*Preventive:* Validates URLs embedded in emails.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Unknown sender -Malicious attachments	VC4	*Declarative:* Knows that attackers send malicious emails to users in order to execute a threat (e.g., sending malicious files as an attachment) and familiar with mechanisms used to validate attachments. *Procedural:* Knows how to validate suspicious attachments and knows about the danger of attachments from unknown senders.	*Severity*: Perceives executing files attached to emails received from spammers/unknown/ suspicious senders as dangerous. *Probability:* Perceives malicious emails (spam emails) containing malicious attachments as something that is likely to occur. *Usefulness:* Perceives validating attachments before they are executed as useful for protecting his/her device.	*Preventive:* Validates attachments received from unknown senders (or spammers). *Confronting:* Does not download and/or execute file attachments classified as malicious or received from unknown senders.
Advertisements	VC5	*Declarative:* Knows that attackers send malicious emails masquerading as an advertisement in order to execute a threat. *Procedural:* Knows how to identify the source of emails and domains.	*Severity*: Understands that opening advertisement emails may put his/her privacy at risk. *Probability:* Perceives malicious emails (spam emails) masquerading as advertisements as something that is likely to occur. *Usefulness:* Perceives avoiding opening advertisements (received from unknown entities) as useful for protecting the device.	*Preventive:* Validates the sender. *Confronting:* Does not open advertisement emails received form unknown senders.
Junk mailbox	VC6	*Declarative:* Knows that attackers send malicious emails (e.g., spam emails, phishing emails) to users in order to execute a threat (e.g., phishing attacks) and familiar with mechanisms used to protect against spam emails. *Procedural:* Knows how to filter spams from his/her mailbox.	*Severity*: Perceives opening emails that are classified as spam as dangerous *Probability:* Perceives malicious emails (spam emails) as something that is likely to occur. *Usefulness:* Perceives that avoiding entering emails classified as spam as useful for protecting the device.	*Preventive:* Validates the sender of an email *Confronting:* Does not open/read messages/emails classified as spam.
Focus area: Browsing and Communications Sub-focus area: Account (A)				
Passwords - Diversity	A1	*Declarative:* Knows that malicious entities may obtain the passwords of users (e.g., by leading the user to insert login details into a phishing or advertisement domain). These passwords can be used to hijack the user's other accounts. Familiar with tools for managing passwords (i.e., keychain services). *Procedural:* Knows how to use keychain services to generate passwords for different services.	*Severity*: Perceives using the same password for several services as dangerous. *Probability:* Perceives exposure of passwords as something that is likely to occur. *Usefulness:* Perceives using keychain services and creating different passwords for different services as useful in protecting his/her accounts.	*Preventive:* Uses keychain services and does not use the same password for different services.
Passwords - Updates	A2	*Declarative:* Knows that malicious entities may obtain user passwords. *Procedural:* Knows how to update the passwords of his/her accounts.	*Severity*: Understands that using default passwords or using the same password for a long period of time may enable attackers to hijack his/her account. *Probability:* Perceives exposure of passwords as something that is likely to occur. *Usefulness*: Perceives updating passwords regularly as useful in protecting his/her account.	*Preventive:* Updates passwords regularly and does not use default passwords. *Confronting:* Does not ignore security alerts (or emails) regarding his/her accounts.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Passwords - Strength	A3	*Declarative:* Knows that attackers may utilize weak/guessable passwords and familiar with tools for managing passwords. *Procedural:* Knows how to use keychain services to generate strong passwords.	*Severity*: Understands that guessable passwords may cause account hijacking. *Probability:* Perceives password cracking as something that is likely to occur. *Usefulness*: Perceives using keychain services and creating strong passwords as useful in protecting his/her accounts.	*Preventive*: Uses strong and unguessable passwords.
Passwords - Storage	A4	*Declarative*: Knows that applications can access sensitive information stored on the device (e.g., SMS, contact list, reminders, etc.). *Procedural:* Knows how to store his/her passwords safely (e.g., keychain services).	*Severity*: Understands that storing passwords unsafely may enable attackers to hijack his/her account. *Probability:* Perceives applications gaining access to data stored on the device as something that is likely to occur. *Usefulness*: Perceives storing passwords safely and using keychain services as useful in protecting his/her accounts.	*Preventive*: Does not store passwords unsafely.
Two-factor authentication	A5	*Declarative:* Knows that malicious entities may obtain user passwords and familiar with two-factor authentication mechanisms. *Procedural*: Knows how to use two-factor authentication services.	*Severity:* Perceives hostile takeover of his/her account by a malicious entity as a danger to his/her privacy. *Probability:* Perceives exposure of passwords as something that is likely to occur. *Usefulness:* Perceives the use of two-factor authentication mechanism as a valuable factor in preserving the privacy of virtual accounts.	*Preventive*: Uses two-factor authentication mechanisms. Confronting: Does not share private authentication details sent to his/her phone with others.
Privacy settings	A6	*Declarative:* Knows that malicious entities utilize publicly available information of users on social media to execute attacks (e.g., spear phishing attacks, dictionary attacks). *Procedural:* Knows how to manage the privacy settings in social media.	*Severity:* Understands that social media may cause information disclosure. *Probability:* Perceives the existence of malicious entities that utilize social media to execute a threat as plausible. *Usefulness:* Perceives that restricting the privacy settings in social media will help to preserve his/her privacy.	*Preventive*: Restricts the privacy settings in social media. *Confronting*: Does not grant sensitive permissions to third party applications and does not approve friendship requests from unknown (suspicious) entities.
Focus area: Device	Sub-focus area: Operating Systems (OS)			
Updates	OS1	*Declarative:* Knows that malicious entities may utilize known vulnerabilities in the OS to execute a threat and familiar with the auto-update mechanism. *Procedural:* Knows how to configure the auto-update mechanism and knows how to update the OS of the device.	*Severity:* Understands that using an outdated OS may decrease the security of the device. *Probability:* Perceives the existence of known vulnerabilities of outdated OSs as plausible. *Usefulness:* Perceives the use of an updated OS, in addition to the auto-updating of critical services as useful in protecting the device.	*Preventive:* Uses an updated OS and configures auto-updates for critical services. *Confronting:* Does not postpone critical updates of the OS (e.g., by ignoring update alerts).

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Vulnerable OS	OS2	*Declarative:* Knows that malicious entities may utilize known vulnerabilities in the OS to execute a threat. *Procedural:* Knows how to search for known OS vulnerabilities (e.g., security blogs or CVE's databases).	*Severity*: Perceives using an OS with known vulnerabilities as very dangerous. *Probability:* Perceives the existence of known vulnerabilities on outdated OSs as plausible. *Usefulness:* Perceives using an OS with no known vulnerabilities and searching for known CVEs as useful for protecting the device.	*Preventive*: Does not use an OS with known vulnerabilities and stays updated regarding known vulnerabilities of his/her OS.
Root/jailbreak	OS3	*Declarative:* Knows that malicious entities may utilize a jailbreak device to execute a threat and familiar with mechanisms used to manage super-user privileges. *Procedural:* Knows how to manage super-user privileges.	*Severity*: Understands that jailbreaking (rooting) the device could be very dangerous. *Probability:* Perceives the existence of malicious entities that utilize super-users as plausible. *Usefulness:* Perceives jailbreak prevention as useful in protecting his/her device	*Preventive*: Does not root or jailbreak the device. *Confronting:* Properly manages super-user privileges (in case he/she must root the device).
Focus area: Device	Sub-focus area: Data Privacy (DP)			
Encryption	DP1	*Declarative:* Knows that sensitive data can be extracted from the device and familiar with mechanisms used to encrypt the data that exists on the device. *Procedural:* Knows how to encrypt the drive of the device.	*Severity*: Understands that extracting unencrypted data from the device may cause information disclosure. *Probability:* Perceives the extraction of data from the device by malicious entities as something that is likely to occur. *Usefulness*: Understands that encryption increases the confidentiality of sensitive information.	*Preventive*: Encrypts the drive of the device. *Confronting:* Does not share his/her PIN-code with others.
Backup	DP2	*Declarative:* Knows that the data on the device could be corrupted and familiar with backup services. *Procedural:* Knows how to perform a backup.	*Severity*: Perceives the corruption of data stored on the device as harmful. *Probability*: Perceives loss of data as something that this is likely to occur. *Usefulness*: Perceives performing a backup of his/her data as useful for avoiding loss of data.	*Preventive*: Uses backup services.
Private data	DP3	*Declarative:* Knows that the data stored on the device could be exposed.	*Severity*: Recognizes the danger in storing sensitive information on the device. *Probability*: Perceives that the information stored on his/her device is valuable for third parties and attackers. *Usefulness:* Perceives preventing the storage of sensitive material on the device as privacy preserving.	*Preventive*: Does not store sensitive material on the device.
Focus area: Device	Sub-Focus area: Security Systems (SS)			
Embedded security systems	SS1	*Declarative:* Knows that smartphone devices are targeted by attackers and familiar with embedded security systems that exist on modern OSs. *Procedural:* Knows how to operate the embedded security systems.	*Severity*: Perceives that security breaches could harm the device. *Probability:* Perceives the probability of security breaches on his/her smartphone as high. *Usefulness:* Perceives the usage of embedded security systems as useful in protecting the device.	*Preventive*: Uses embedded security systems. *Confronting:* Does not ignore security alerts related to the embedded security systems.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Antivirus	SS2	*Declarative:* Knows that smartphone devices are targeted by attackers and familiar with the existence of mobile antiviruses. *Procedural:* Knows how to use mobile antiviruses.	*Severity*: Perceives that security breaches can harm the device. *Probability:* Perceives the probability of security breaches on his/her smartphone as high. *Usefulness:* Perceives the use of antivirus as useful in protecting the device.	*Preventive*: Uses antivirus application regularly to scan the device. *Confronting:* Does not ignore security alerts from the antivirus application.
Mobile device management (MDM)	SS3	*Declarative:* Knows that smartphone devices are targeted by attackers and familiar with the existence of MDM solutions. *Procedural:* Knows how to use the MDM application.	*Severity*: Perceives security breaches as harmful to the device. *Probability:* Perceives the probability of security breaches on his/her smartphone as high. *Usefulness:* Perceives the use of MDM as useful in protecting the device.	*Preventive*: Uses MDM services. *Confronting:* Does not ignore security alerts from the MDM application.
Security updates	SS4	*Declarative:* Knows that security measures need to be updated in order to address new threats. *Procedural:* Knows how to update the security measures.	*Severity:* Perceives that using an outdated security measure may decrease the security of his/her device. *Probability:* Perceives the probability of security breaches on his/her smartphone as high. *Usefulness:* Perceives updating security systems as useful in protecting the device.	*Preventive*: Updates security systems.
Security alerts	SS5	*Declarative:* Knows that security measures commonly alert the user in the case of a security breach. *Procedural:* Understands the content of security alerts.	*Severity:* Perceives that ignoring security alerts may decrease the security of the device. *Probability:* Perceives the probability of security breaches on his/her smartphone as high. *Usefulness:* Perceives complying with security alerts as useful in protecting the device.	*Confronting:* Operates in accordance with security alerts (i.e., does not ignore security alerts).
Remote deletion services	SS6	*Declarative:* Knows that sensitive data could be extracted from the device and familiar with mechanisms used to delete the data stored on the device remotely. *Procedural:* Knows how to operate remote deletion services.	*Severity*: Perceives that extracting data from the device may cause information disclosure. *Probability:* Perceives the extraction of data from the device as something that is likely to occur. *Usefulness*: Perceives the use of remote deletion services as useful in preserving his/her privacy.	*Preventive*: Installs remote deletion services on the device. *Confronting*: Erases the device if it has been lost.
PIN-code	SS7	*Declarative:* Knows that sensitive data could be extracted from the device and familiar with mechanisms used to prevent unauthorized entities from accessing data stored on the device. *Procedural:* Knows how to set a PIN-code.	*Severity*: Perceives that extracting data from the device may cause information disclosure. *Probability:* Perceives the extraction of data from the device as something that is likely to occur. *Usefulness*: Perceives the use of a PIN-code as useful in preserving his/her privacy.	*Preventive*: Uses PIN-codes/patterns/fingerprinting. *Confronting*: Does not share his/her PIN-code with others.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Focus area: Communication Channels Sub-focus area: Networks (N)				
Wi-Fi – Auto-connect	N1	*Declarative*: Knows that attackers can impersonate a Wi-Fi network. *Procedural:* Knows how to prevent the device from auto-connecting to unknown Wi-Fi networks.	*Severity*: Perceives that connecting to unknown Wi-Fi networks could cause information leakage. *Probability:* Perceives the connection to malicious Wi-Fi networks as something that is likely to occur. *Usefulness*: Perceives that preventing the device from auto-connecting to an unknown Wi-Fi network is useful in preserving privacy.	*Preventive*: Does not auto-connect to unknown Wi-Fi networks.
Wi-Fi - Unencrypted networks	N2	*Declarative*: Knows that attackers can impersonate a Wi-Fi network. *Procedural:* Knows how to prevent the device from connecting to an unencrypted Wi-Fi network.	*Severity*: Perceives that connecting to unencrypted Wi-Fi networks could cause information leakage. *Probability:* Perceives malicious Wi-Fi networks as something that is likely to occur. *Usefulness*: Perceives that preventing the device from connecting to an unencrypted Wi-Fi network is useful in preserving privacy.	*Preventive*: Does not connect to unencrypted networks.
Wi-Fi - Unencrypted networks	N3	*Declarative*: Knows that attackers can change files downloaded via unencrypted Wi-Fi networks. *Procedural:* Knows how to validate the signature of a file.	*Severity*: Perceives that downloading files via unencrypted Wi-Fi networks can harm his/her device. *Probability:* Perceives malicious Wi-Fi networks as something that is likely to occur. *Usefulness*: Perceives that preventing downloading files via unencrypted Wi-Fi networks and validating the signature of files downloaded via unencrypted Wi-Fi networks as useful in preserving privacy.	*Preventive*: Does not download files on unencrypted Wi-Fi networks. *Confronting*: Validates the signature of files and does not execute a file with an incorrect signature.
VPN	N4	*Declarative*: Knows that attackers can impersonate a Wi-Fi network. *Procedural:* Knows how to protect the device in a public network (VPN services).	*Severity*: Perceives that connecting to unknown Wi-Fi networks could cause information leakage. *Probability:* Perceives malicious Wi-Fi networks as something that is likely to occur. *Usefulness*: Perceives the use of VPNs as useful is in preserving privacy.	*Preventive*: Uses VPN services on public networks.
Wi-Fi - Unencrypted networks	N5	*Declarative*: Knows that attackers can impersonate a Wi-Fi network. *Procedural:* Knows how to preserve his/her privacy while operating in an unknown Wi-Fi network.	*Severity*: Perceives that connecting to unknown Wi-Fi networks could cause information leakage. *Probability:* Perceives malicious Wi-Fi networks as something that is likely to occur. *Usefulness*: Perceives that preventing the transmission of private data via unencrypted channels is useful in protecting privacy.	*Preventive*: Does not transmit private data via unencrypted channels.

(*continued on next page*)

Topic	ID	Knowledge	Attitude	Behavior
Focus area: Communication Channels Sub-focus area: Physical Channels (PC)				
NFC/Bluetooth	PC1	*Declarative*: Knows that NFC and Bluetooth protocols can be easily compromised by an attacker. *Procedural:* Knows how to configure the NFC/Bluetooth settings.	*Severity*: Perceives that compromised NFC/Bluetooth protocols can cause significant harm to the device. *Probability:* Perceives attacks on NFC/Bluetooth connections as likely to occur. *Usefulness*: Perceives enabling Bluetooth and NFC only while they are being used as useful in protecting privacy.	*Preventive*: Enables Bluetooth and NFC while they are in use and only connects trusted Bluetooth and NFC devices.
USB/charging connections	PC2	*Declarative*: Knows that attackers can execute an attack through the USB/charging connection. *Procedural:* Knows how to behave carefully with USB connections.	*Severity*: Perceives that compromising the USB/charging connection can cause significant harm to the device. *Probability:* Perceives attacks on a USB/charging connection as something that is likely to occur. *Usefulness*: Perceives that a careful behavior can help mitigate most of these attacks.	*Preventive*: Does not use a USB to connect the device to unknown devices.
Physical access	PC3	*Declarative*: Knows what actions a malicious entity could perform with physical access to the device and knows that attackers can use physical access to execute a threat. *Procedural:* Knows how to set a PIN-code.	*Severity*: Perceives that physical access to the device by a malicious entity could cause information leakage or damage his/her device. *Probability:* Perceives that malicious entities that obtain physical access to the device is something that is likely to occur. *Usefulness*: Perceives that making sure the device is attended and the use of a PIN-code can help mitigate most of these attacks.	*Preventive*: Does not keep the device unattended and uses a PIN-code. *Confronting*: Does not share his/her PIN-code with others.

REFERENCES

Albrechtsen E. A qualitative study of users' view on information security. Comput Sec 2007;26(4):276–89.

Allam S, Flowerday SV, Flowerday E. Smartphone information security awareness: a victim of operational pressures. Comput Sec 2014;42:56–65.

Androulidakis I, Kandus G. Mobile phone security awareness and practices of students in Budapest, in ICDT 2011, The Sixth International Conference on Digital Telecommunications; 2011a.

Androulidakis I, Kandus G. Bluetooth® usage among students as an indicator of security awareness aand feeling, in 53rd International Symposium, Zadar, Croatia; 2011b.

Androulidakis I, Kandus G. A survey on saving personal data in the mobile phone, in Availability, Reliability and Security (ARES), IEEE, Vienna; 2011c.

Asanka N, Love S. Security awareness of computer users: a phishing threat avoidance perspective. Comput Human Behav 2014;38:304–12.

Beekman J, Thompson C. Man-in-the-middle attack on T-Mobile Wi-Fi calling, Berkeley University of Califorina, 18 March; 2013. [Online]. Available from: https://www2.eecs.berkeley.edu/Pubs/TechRpts/2013/EECS-2013-18.pdf.

Boyatzis RE, Kolb DA. Assessing individuality in learning: the learning skills profile. Educl Psychol 1991;11(3–4):279–95.

Carlton M, Levy Y, Ramim M, Terrel S. Development of the MyCyberSkills™ iPad App: a scenarios-based, hands-on measure of non-it professionals' cybersecurity skills, in Workshop on Information Security and Privacy (SIGSEC); 2015.

Damopoulos D, Kambourakis G, Gritzalis S. iSAM: an iPhone stealth airborne malware. IFIP Adv Inf Commun Technol 2011;17–28.

Danchev D. Man-in-the-middle attacks demoed on 4 smartphones, ZDNET, 13 November; 2013. [Online]. Available from: http://www.zdnet.com/article/man-in-the-middle-attacks-demoed-on-4-smartphones/.

Esmaeili M. Assessment of users information security behavior in smartphone, Master's Theses and, p. Paper 581; 2014.

Felt AP, Finifter M, Chin E, Hanna S, Wagner D. A survey of mobile malware in the wild, in ACM Conference on Computer and Communications Security, New York, NY, USA, 2011.

Foozy CFM, Ahmad R, Abdollah MF, Yusof R, Mas'ud MZ. Generic taxonomy of social engineering attack and defence mechanism for handheld computer study, in Malaysian Technical Universities International Conference on Engineering & Technology, Batu Pahat, Johor; 2011.

Forristal J. Android fake ID vulnerability lets malware impersonate trusted applications, puts all android users since January 2010 at risk, BLUEBOX, 29 July; 2014. [Online]. Available from: https://bluebox.com/technical/android-fake-id-vulnerability/.

Gluck T, Puzis R, Oren Y, Shabtai A. The curious case of the curious case: detecting touchscreen events using a smartphone protective case, in Workshop on Security for Embedded and Mobile Systems, Paris; 2017.

Greenberg A. New mobile exploits demonstrated at Pwn2Own event, SC Magazine, 13 November; 2013. [Online]. Available from: http://www.scmagazine.com/new-mobile-exploits-demonstrated-at-pwn2own-event/article/320836/.
Haris M, Haddadi H, Hui P. Privacy leakage in mobile computing: tools, methods, and characteristics, in arXiv:1410.4978 [cs.CR]; 2014.
He D, Chan S, Guizani M. Mobile application security: malware threats and defenses. IEEE Wireless Commun 2015;22(1):138–44.
Hypponen M. Malware Goes Mobile. Sci Am 2006;297:70–7.
Karikoski J, Soikkeli T. Contextual usage patterns in smartphone communication services. Perso Ubiquitous Computing 2013;17(3):491–502.
Kelley PG, Consolvo S, Cranor LF, Jung J, Sadeh N, Wetherall D. A conundrum of permissions: installing applications on an android smartphone. Int Financ Cryptography Assoc 2012;68–79.
Kesh S, Ratnasingam P. A knowledge architecture for IT security, in Communications of the ACM – Creating a science of games, New York; 2007;50(7):103–8.
Krombholz K, Hobel H, Huber M, Edgar W. Advanced social engineering attacks. J Inf Sec Appl 2014;22:113–22. vol. Available online 24 October 2014.
Kruger H, Kearney W. A prototype for assessing information security. Comput Sec 2006;25:289–96.
Kruger HA, Drevin L, Steyn T. A framework for evaluating ICT security awareness, in Proceedings of the ISSA 2006 from Insight to Foresight Conference, Sandton, South Africa; 2006.
La Polla M, Martinelli F, Sgandurra D. A Survey on Security for Mobile Devices. IEEE Commun Surv Tutorials 2013;15(1):446–70.
Lackey Z, Miras L. Attacking SMS. Las Vegas, NV: BlackHat USA; 2009.
Lau B, Jang Y, Song C, Wang T, Chung PH, Royal P. Mactans: injecting malware into iOS devices via malicious chargers. Las Vegas, NV: BlackHat USA; 2013.
Leopando J. (Communications). Android vulnerability affects 99% of devices – trend micro users protected Trend Micro, 10 July; 2013. [Online]. Available from: http://blog.trendmicro.com/trendlabs-security-intelligence/trend-micro-solution-for-vulnerability-affecting-nearly-all-android-devices/.
Messmer E. Apple iOS apps subject to man-in-the-middle attacks, Network World, 29 October; 2013. [Online]. Available from: https://www.networkworld.com/article/2171269/network-security/apple-ios-apps-subject-to-man-in-the-middle-attacks.html.
Miller C. Mobile attacks and defense. Sec Priv, IEEE 2011;9(4):68–70.
Mylonas A, Kastania A, Gritzalis D. Delegate the smartphone user? Security awareness in smartphone platforms. Comput Sec 2013;34:47–66.
Mylonas A, Theoharidou M, Gritzalis D. Assessing privacy risks in android: a user-centric approach. In: Risk assessment and risk-driven testing. Springer International Publishing; 2014. p. 21–37.
Ng BY, Rahim M. A socio-behavioral study of home computer users' intention to practice security, in PACIS 2005 Proceedings; 2005.
Oliver S. Researcher accuses apple of ignoring iCloud brute-force attack for 6 months, apple insider, 25 September; 2014. [Online]. Available from: http://appleinsider.com/articles/14/09/25/researcher-accuses-apple-of-ignoring-icloud-brute-force-attack-for-6-months.
Paganini P. Gmail app for iOS vulnerable to man-in-the-middle attacks, Secuirty Affairs, 12 July; 2014. [Online]. Available from: http://securityaffairs.co/wordpress/26577/hacking/gmail-app-flaw-mitm.html.
Park JH, Yi KJ, Jeong Y-S. An enhanced smartphone security model based on information security management system (ISMS). Electron Commer Res 2014;11:321–48.
Peng S, Yu S, Yang A. Smartphone malware and its propagation modeling: a survey. Commun Surv Tutorials, IEEE 2014;16(2):925–41.
Pittayachawan S, Dang-Pham D. Comparing intention to avoid malware across contexts in a BYOD-enabled Australian university: a Protection Motivation Theory approach. Comp Sec 2014;48:281–97. http://dx.doi.org/10.1016/j.cose.2014.11.002.
Prabhu G. iOS 7.1 bug allows disabling of find my iPhone without a password, Iphone Hacks, 3 April; 2014. [Online]. Available from: http://www.iphonehacks.com/2014/04/ios-7-1-bug-allows-disabling-find-iphone-without-password.html.
Rainie L. Anonymity, privacy, and security online, Pew Research Center; 2013.
Saaty TL. The analytic hierarchy process. In: Mathematical models for decision support. Berlin: Springer Berlin Heidelberg; 1988. p. 109–21.
Saran C. Apple users at risk of SSL man-in-the-middle attacks, Computers Weekly, 24 February; 2014. [Online]. Available from: http://www.computerweekly.com/news/2240214897/Apple-users-at-risk-of-SSL-man-in-the-middle-attack.
Shwartz O, Shitrit G, Shabtai A, Oren Y. From smashed screens to smashed stacks: attacking mobile phones using malicious aftermarket parts, in Workshop on Security for Embedded and Mobile Systems, Paris, 2017.
Siponen M. Five dimensions of information security awareness. ACM SIGCAS Comput Soc 2001;31(2):24–9.
Stanton JM, Stam KR, Mastrangelob P, Joltonb J. Analysis of end user security behaviors. Comput Sec 2005;24(2):124–33.
Tenenboim-Chekina L, Barad O, Shabtai A, Mimran D, Rokach L, Shapira B, et al. Detecting application update attack on mobile devices through network features, in Computer communications workshops, Turin; 2013.
Thomas K. Consequences of connectivity: characterizing account hijacking on twitter, in CCS "14 Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security; 2014.
Thompson ME, Von Solms R. Information security awareness: educating your users effectively. Inf Manage Comput Sec 1998;6(4):167–73.
Tung L. Half of all Android devices still vulnerable to 'privacy disaster' browser bug, ZDNET, 9 October; 2014. [Online]. Available from: http://www.zdnet.com/article/half-of-all-android-devices-still-vulnerable-to-privacy-disaster-browser-bug/.
Vidas T, Votipka D, Christin N. All your droid are belong to us: a survey of current android attacks, in WOOT'11 Proceedings of the 5th USENIX conference on offensive technologies, San Francisco; 2011.
Virvilis N, Tsalis N, Mylonas A, Gritzalis D. Mobile devices: a phisher's paradise, in Proc. of the 11th International Conference on Security and Cryptography; 2014.
Zhou Y, Jiang X. Dissecting android malware: characterization and evolution, in IEEE Security and Privacy, San Francisco, CA; 2012.
Zhu H, Xiong H, Ge Y, Chen E. Mobile app recommendations with security and privacy awareness, in KDD '14 Proceedings of the 20th ACM SIGKDD international conference on Knowledge discovery and data mining, New York, NY, USA; 2014.

Lior Rokach is a data scientist and a Full Professor in the Department of Software and Information Systems Engineering at Ben-Gurion University of the Negev, Israel. His research interests lie in

the design and analysis of Machine Learning and Data Mining algorithms and their applications in Cyber Security, Recommender Systems and Information Retrieval. Prof. Rokach is the author of over 200 peer reviewed papers in leading journals, conference proceedings, patents, and book chapters. In addition, he has authored six books and edited five books.

Asaf Shabtai is a senior lecturer (Assistant Professor) in the Department of Software and Information Systems Engineering at Ben-Gurion University (BGU) of the Negev. Asaf is a recognized expert in information systems security and has led several large-scale researches in this field. His main areas of interests are: computer and network security, machine learning, security awareness, IoT security, and security of avionic systems. Shabtai has published over 70 refereed papers in leading journals and conferences. In addition, he has co-authored a book on information leakage detection and prevention. Shabtai received a PhD in information systems engineering (2011) from Ben-Gurion University.

Rami Puzis is a senior lecturer (Assistant Professor) in the Department of Software and Information Systems Engineering at Ben-Gurion University (BGU) of the Negev. He received a PhD with honors in information systems engineering from Ben-Gurion University in 2010 and was a post-doctoral research associate in Laboratory of Computational Cultural Dynamics in the University of Maryland Institute for Advanced Computer Studies. Rami's main research interests are in the analysis of complex systems with applications to cyber security, social networks, and biological networks. He has led several large-scale research projects and published over 50 refereed papers in leading scientific journals and conferences.

Ron Bitton is a PhD candidate in the department of Software and Information Systems Engineering at Ben-Gurion University of the Negev. Over the last two years he is investigating the domain of cyber security, especially the applicability of machine learning algorithms in cyber security solutions, and security awareness. He currently manages two research projects in the Cyber Security Research Center at BGU: a framework for assessing human factor vulnerabilities, and a proxy-based security solution for remote desktop connections in mission-critical systems. His research interests include: machine learning, anomaly detection, smartphone security, security awareness, and security of avionic systems.

Andrey Finkelshtein is an MSc graduate in the department of Software and Information Systems Engineering at Ben-Gurion University. His research interests include: machine learning and human factors of computer and network security.

Lior Sidi is a data scientist at the Telekom Innovation Laboratories at Ben-Gurion University (BGU) of the Negev, specializing in the cyber security domain. His main areas of interests are: computer and network security, fraud detection and prevention, security awareness, machine learning, adversarial learning and big data platforms.